

Compliance as Code using Checkov in Terraform

“Revolutionizing Infrastructure Security and Compliance”

Kosseila Haddalene
Eclipsys Solution Inc

Compliance as Code using **Checkov** in terraform



Kosseila Haddalene
Eclipsys Solution Inc

Compliance as Code using **Checkov** in terraform



"Revolutionizing Infrastructure Security and Compliance"

Kosseila Haddalene
Eclipsys Solution Inc

Compliance as Code using **Checkov** in terraform



“Revolutionizing Infrastructure Security and Compliance”

Kosseila Haddalene
Eclipsys Solution Inc

Hi, I'm Kosseila

Cloud Dude



- I live in Toronto 🇧🇪🇨🇦
- ~17 years infra
- Blogger/Speaker
- IaC/DevOps enthusiast
- Podcaster
- Beatmaker 🎧🎵🎧

 brokedba.com

 [Twitter.com/CloudDude_](https://twitter.com/CloudDude_)

 [Linkedin.com/in/kousshd](https://linkedin.com/in/kousshd)

 [GitHub.com/brokedba](https://github.com/brokedba)

Kosseila Hd Solutions architect @Eclipsys



Hi, I'm Kosseila

Cloud Dude



brokedba.com



Twitter.com/CloudDude_



Linkedin.com/in/kousshd

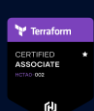


GitHub.com/brokedba

- I live in Toronto 🇧🇪🇨🇦
- ~17 years infra
- Blogger/Speaker
- IaC/DevOps enthusiast
- Podcaster
- Beatmaker 🎧🎵🎧



Kosseila Hd Solutions architect @Eclipsys



Oracle ACE
Pro

Hi, I'm Kosseila

Cloud Dude



brokedba.com



Twitter.com/CloudDude_



Linkedin.com/in/kousshhd

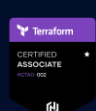


GitHub.com/brokedba

- I live in Toronto 🇧🇪🇨🇦
- ~17 years infra
- Blogger/Speaker
- IaC/DevOps enthusiast
- Podcaster
- Beatmaker 🎧🎵🎧



Kosseila Hd Solutions architect @Eclipsys



Hi, I'm Kosseila

Cloud Dude



 brokedba.com

 [Twitter.com/CloudDude_](https://twitter.com/CloudDude_)

 [Linkedin.com/in/kousshd](https://linkedin.com/in/kousshd)

 [GitHub.com/brokedba](https://github.com/brokedba)

- I live in Toronto  
- ~17 years infra
- Blogger/Speaker
- IaC/DevOps enthusiast
- Podcaster
- Beatmaker   

Tech Beats Unplugged



Kosseila Hd Solutions architect @Eclipsys



AGENDA

1- Security posture (context)

- ❑ Old school VS New School
- ❑ IaC Source of misconfiguration (report)

2- Compliance as Code

- ❑ Solutions in the market (OPA/Cloud native)
- ❑ Why checkov
- ❑ Key features & benefits
- ❑ Explore Checkov with terraform (Install, Prerequisites, Usage, Demo)

3- Shift left with Checkov in CI/CD

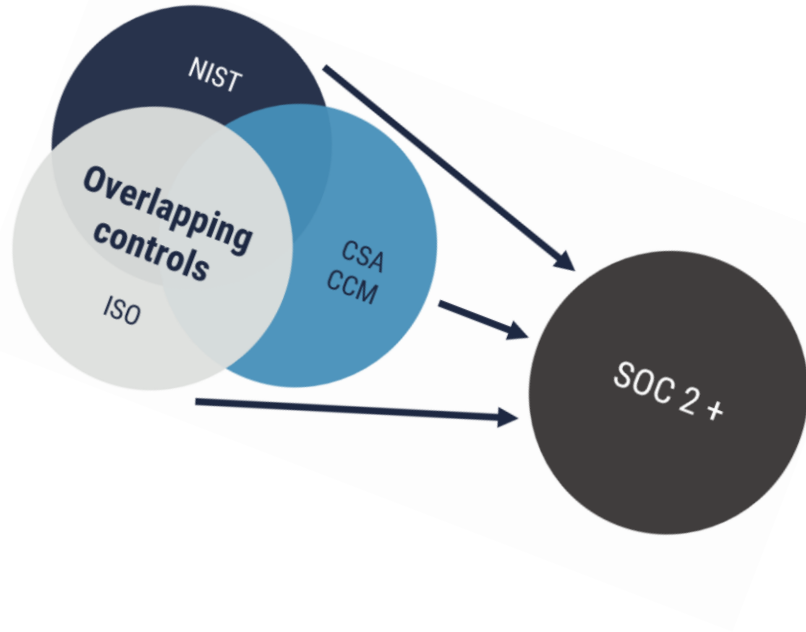
- ❑ Integration with CI pipelines workflow overview
- ❑ Pretty HTML report of Scan Results (GitHub Actions, Azure Devops)
- ❑ Demo & What's Next

4- Q&A

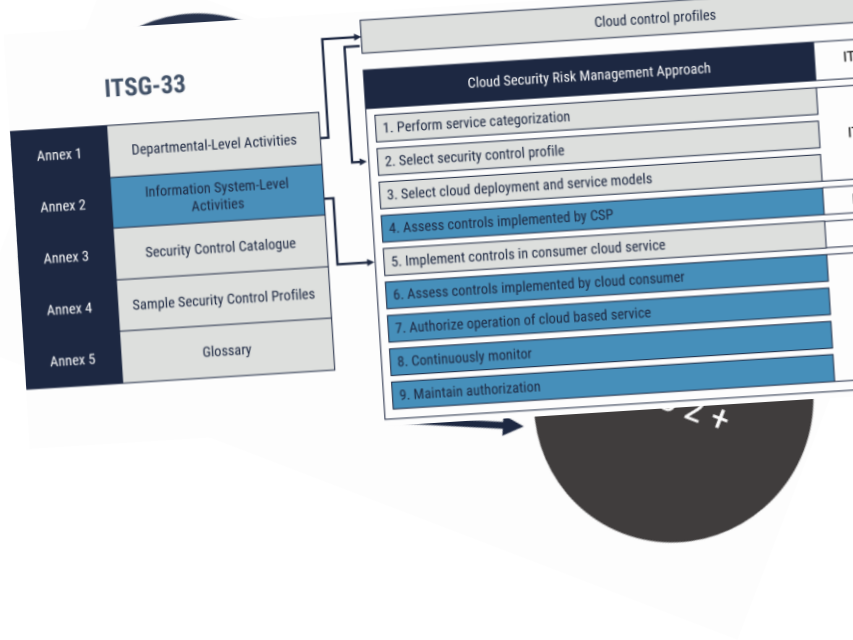
**My FACE When I'm asked to convert 350 Canadian security controls
into Cloud policies (ITSG-33 🍁)**



My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)



My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)



Intro Cloud policies (ITSG-33)

Cloud control profiles	ITS
Cloud Security Risk Management Approach	ITS
Authorization	IT
Models	IT

ITSG-33

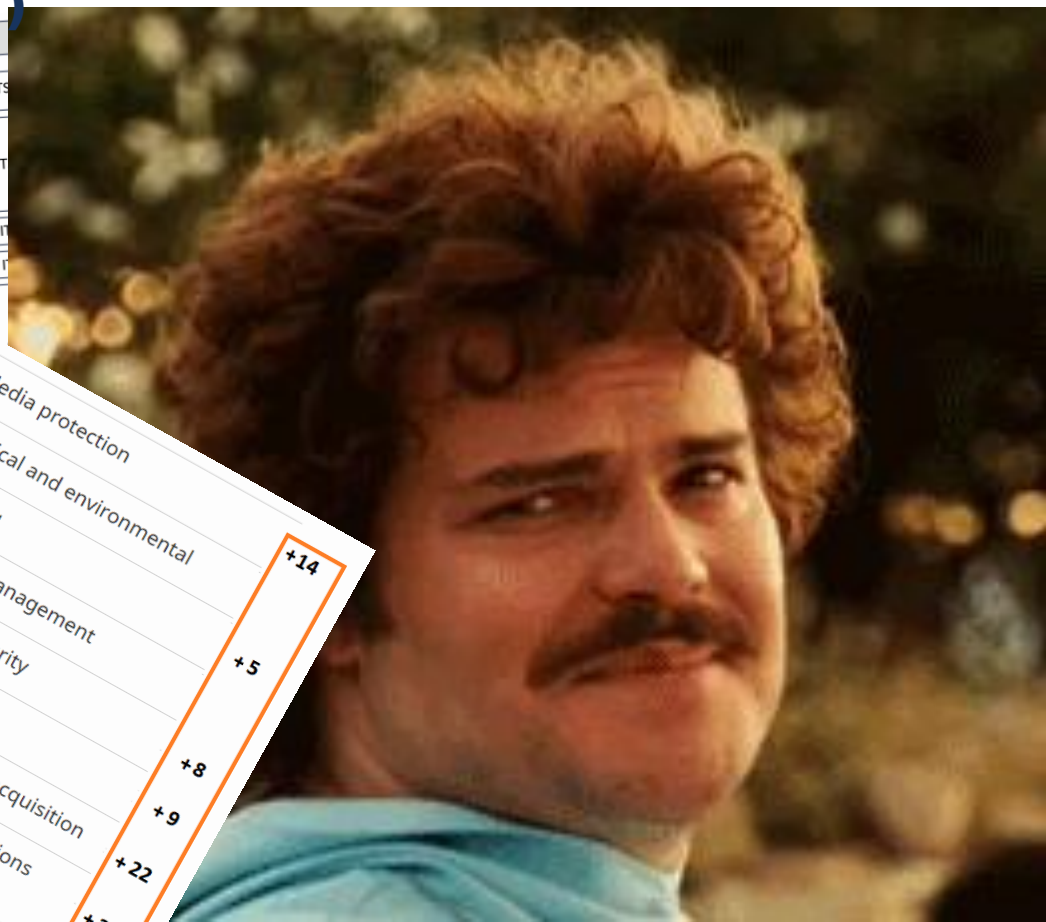
Annex 1	Annex 2	Annex 3	Annex 4
Dep	CA	CM	CP
TA	IR	MA	

Cloud Security Risk Management Approach

Cloud control profiles	ITS
Access control	AC
Awareness and training	AT
Audit & accountability	AU
Security assessment and authorization	CA
Configuration management	CM
Contingency planning	CP
Identification and authentication	IA
Incident response	IR
Maintenance	MA

Cloud Security Risk Management Approach

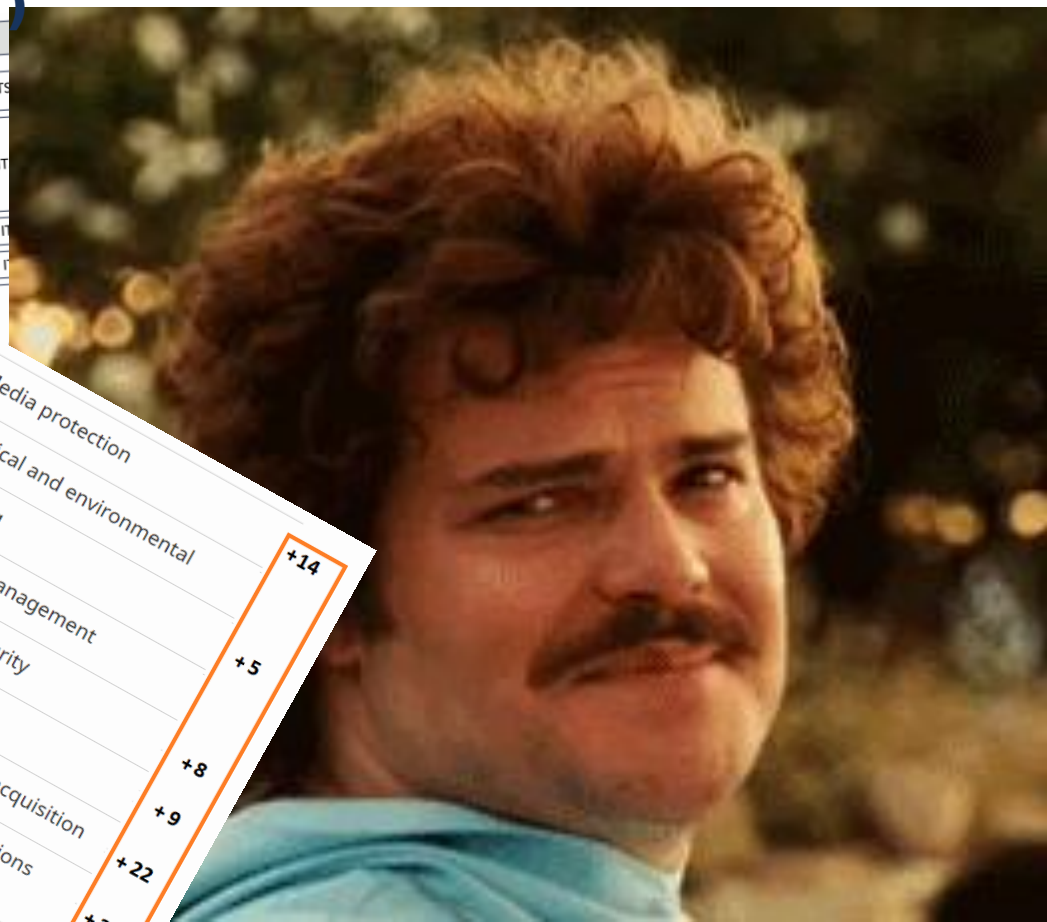
Cloud control profiles	ITS
Media protection	MP
Physical and environmental	PE
Planning	PL
Program management	PM
Personnel security	PS
Risk assessment	RA
System and services acquisition	SA
System and communications protection	SC
System and information integrity	SI



My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)



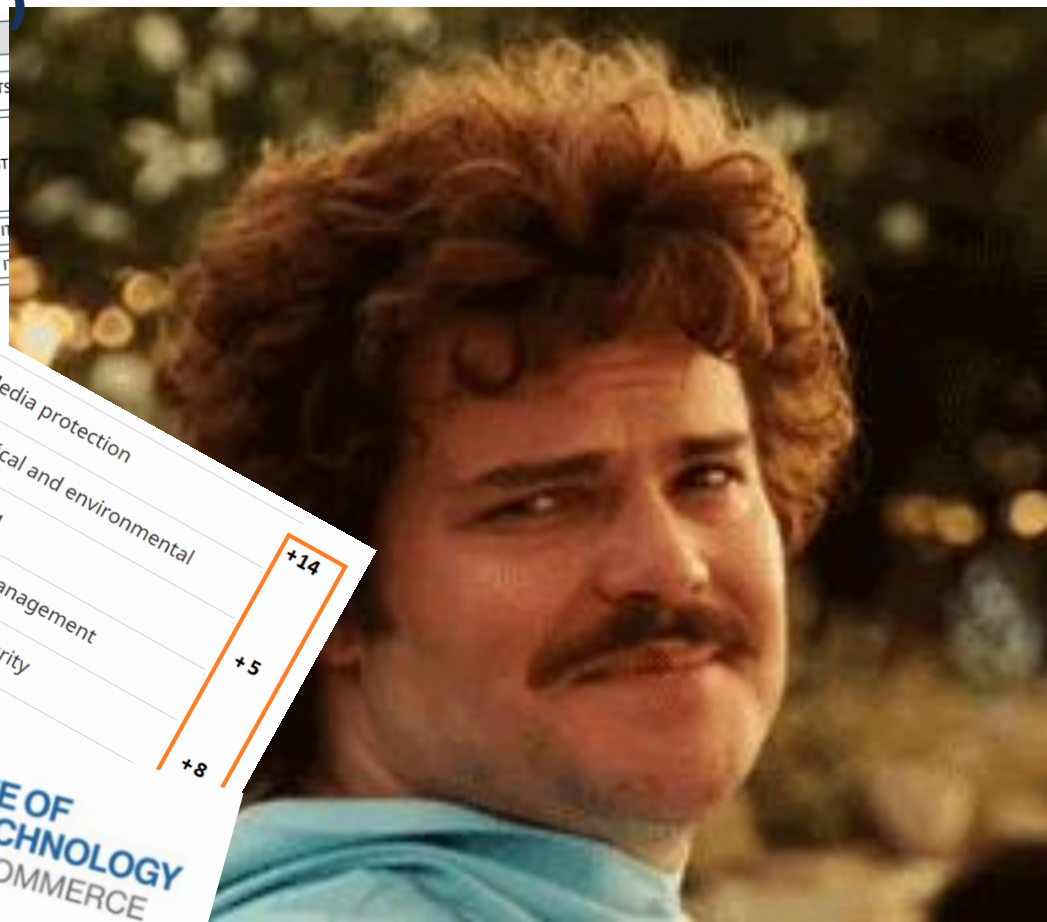
ITSG-33	Cloud control profiles	
AC	Access control	
AT	Awareness and training	
AU	Audit & accountability	
CA	Security assessment and authorization	
CM	Configuration management	+ 15
CP	Contingency planning	+ 30
IA	Identification and authentication	+ 35
IR	Incident response	+ 25
MA	Maintenance	+ 19
		+ 17
MP	Media protection	+ 14
PE	Physical and environmental	
PL	Planning	+ 5
PM	Program management	
PS	Personnel security	+ 8
RA	Risk assessment	+ 9
SA	System and services acquisition	+ 22
SC	System and communications protection	+ 37
SI	System and information integrity	



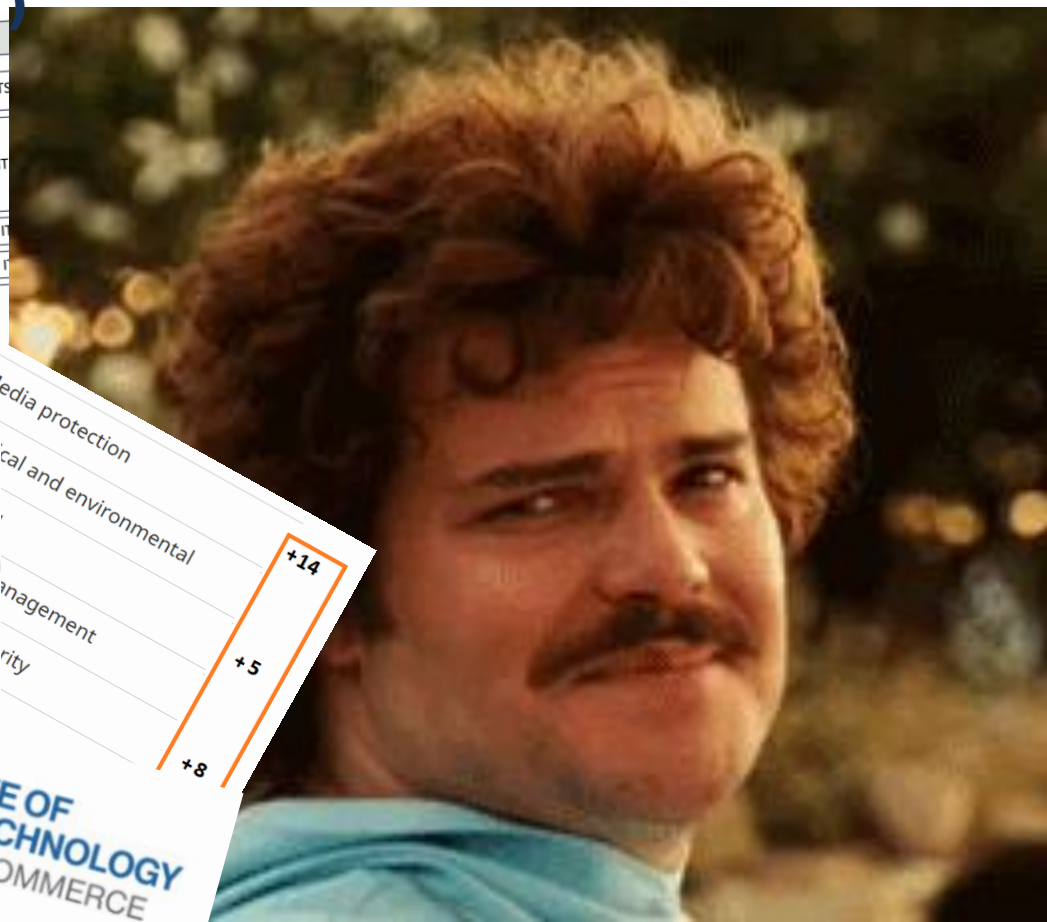
My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)



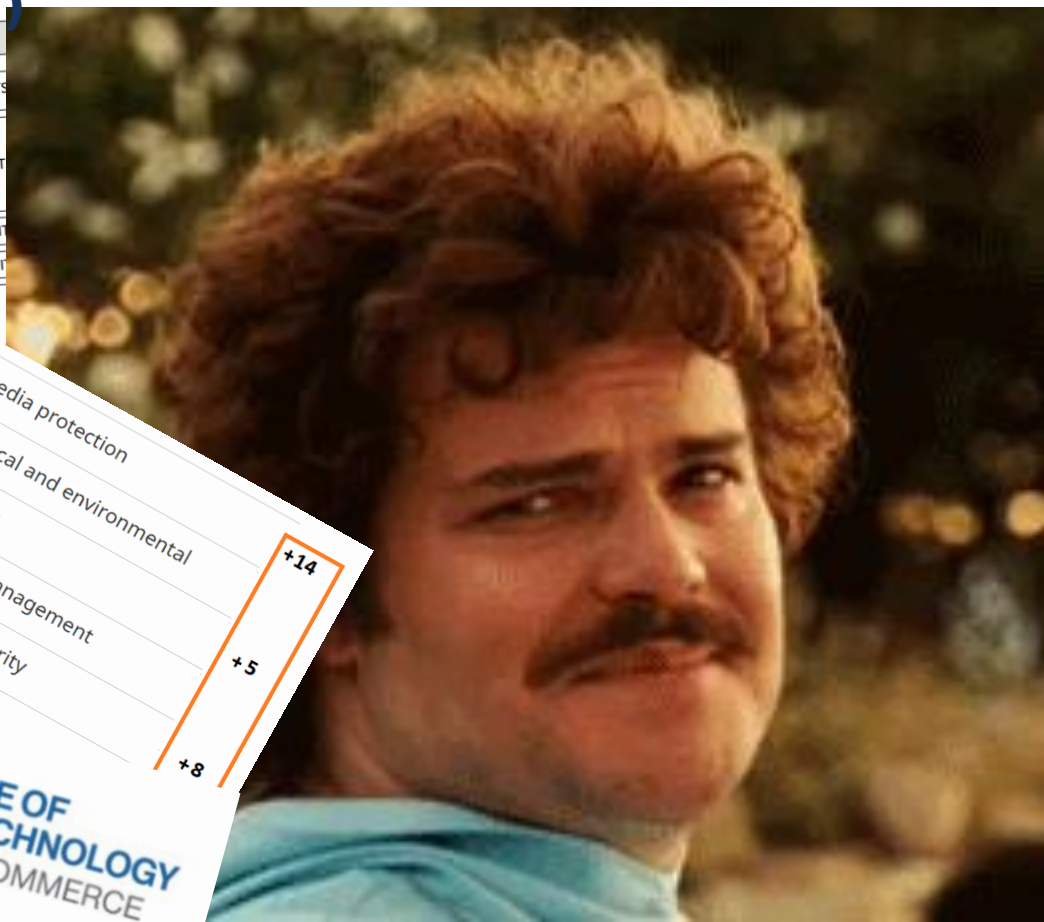
My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)



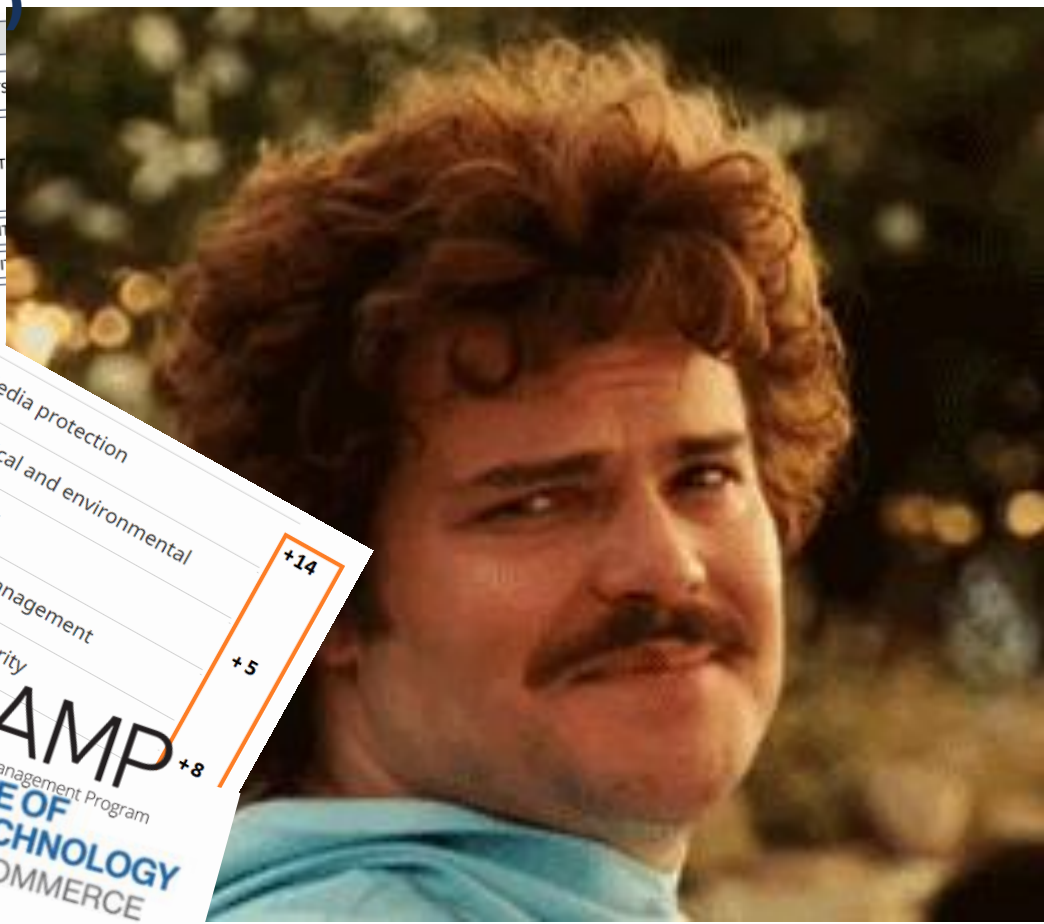
My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)



My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)

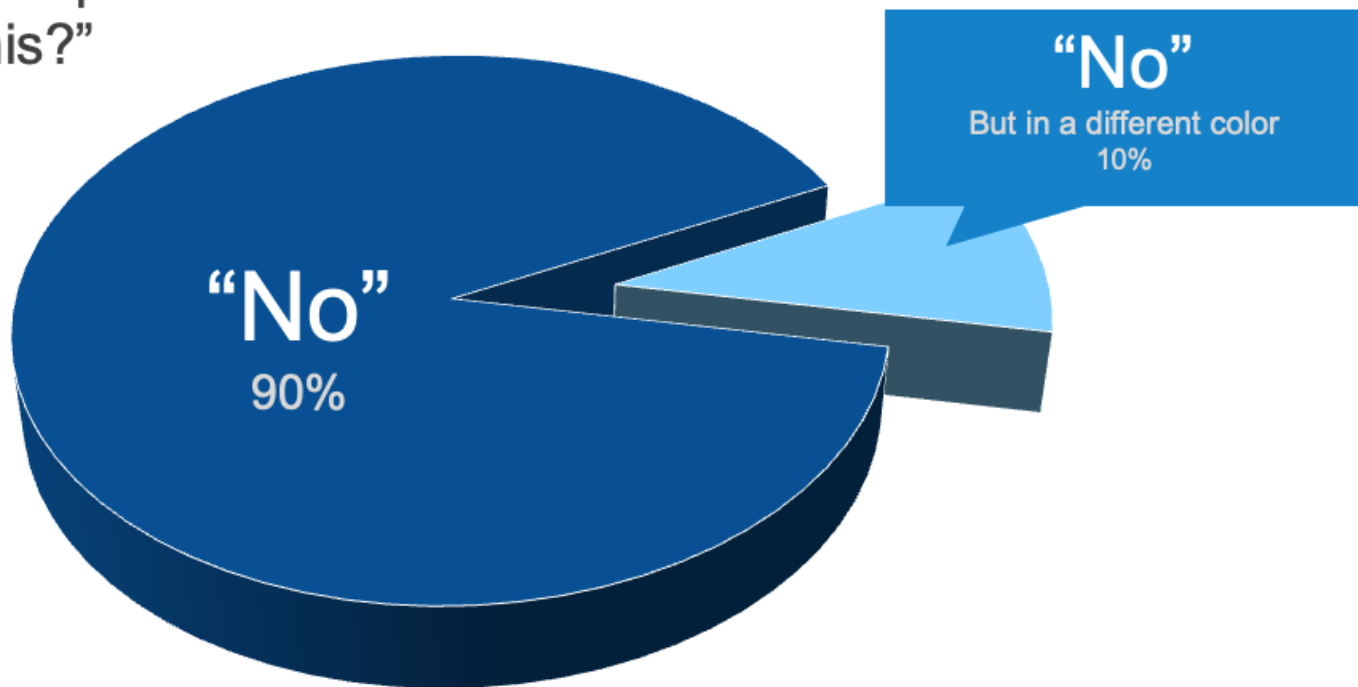


My FACE When I'm asked to convert 350 Canadian security controls into Cloud policies (ITSG-33 🍁)



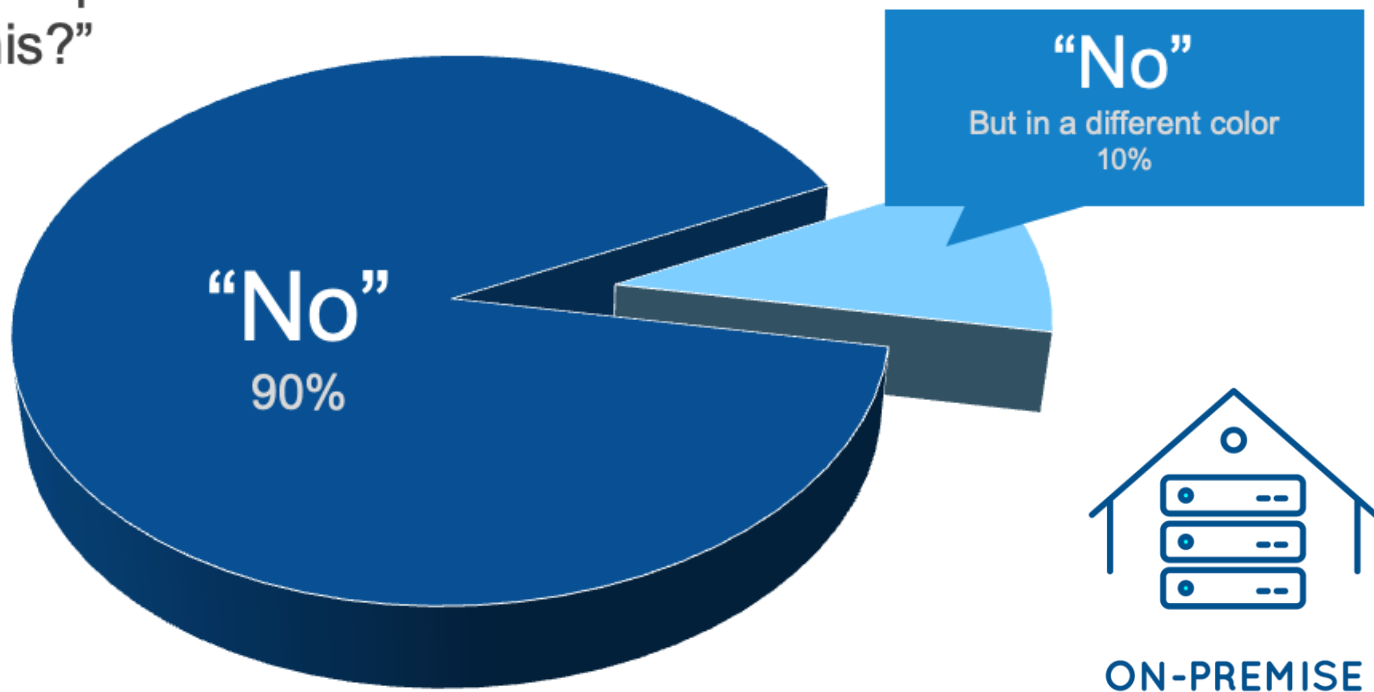
Department of “No-it-alls” (Aka Security)

Typical CISO response to
“Can we do this?”



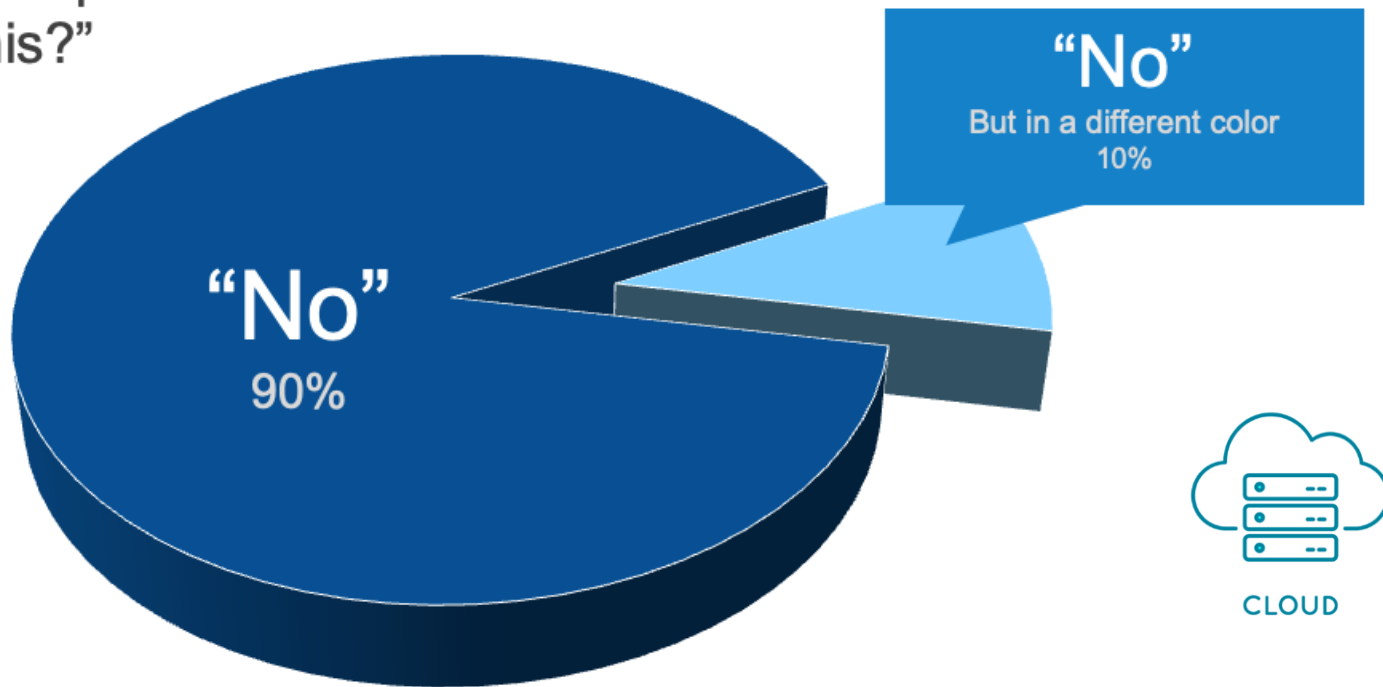
Department of “No-it-alls” (Aka Security)

Typical CISO response to
”Can we do this?”



Department of “No-it-alls” (Aka Security)

Typical CISO response to
”Can we do this?”



Tectonic shift in responsibility (from No to Know)

WORK FASTER
& MORE AGILE



Alibaba Cloud



IBM Cloud

ORACLE



CLOUD

Tectonic shift in responsibility (from No to Know)

WORK FASTER
& MORE AGILE



CIS Azure 1.1
NIST-800-53
CIS AWS 1.2
CIS GCP 1.1
CIS KUBERNETES
SOC2
HIPAA
PCI-DSS 3.2

Alibaba Cloud



(Two scenarios)

Tectonic shift in responsibility (from No to Know)

WORK FASTER
& MORE AGILE



CIS Azure 1.1
NIST-800-53
CIS AWS 1.2
CIS GCP 1.1
CIS KUBERNETES
SOC2
HIPAA
PCI-DSS 3.2

Alibaba Cloud



(Two scenarios)

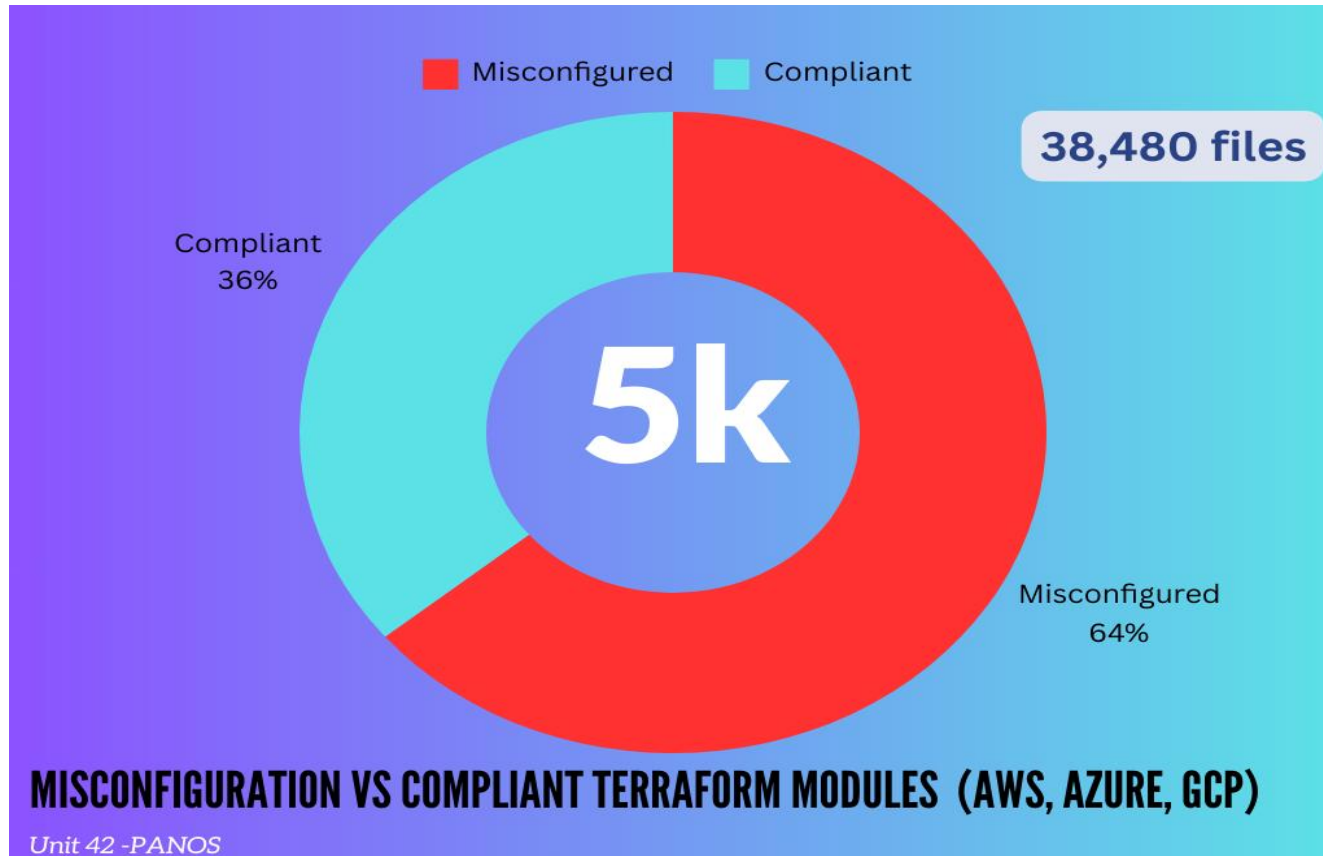
IDENTIFY AND CORRECT
MISCONFIGURED RESOURCES

95%

of cloud security issues
are related to config errors

Source of misconfiguration

Security Teardown: Terraform Modules



Source of misconfiguration

Security Teardown: Terraform Modules

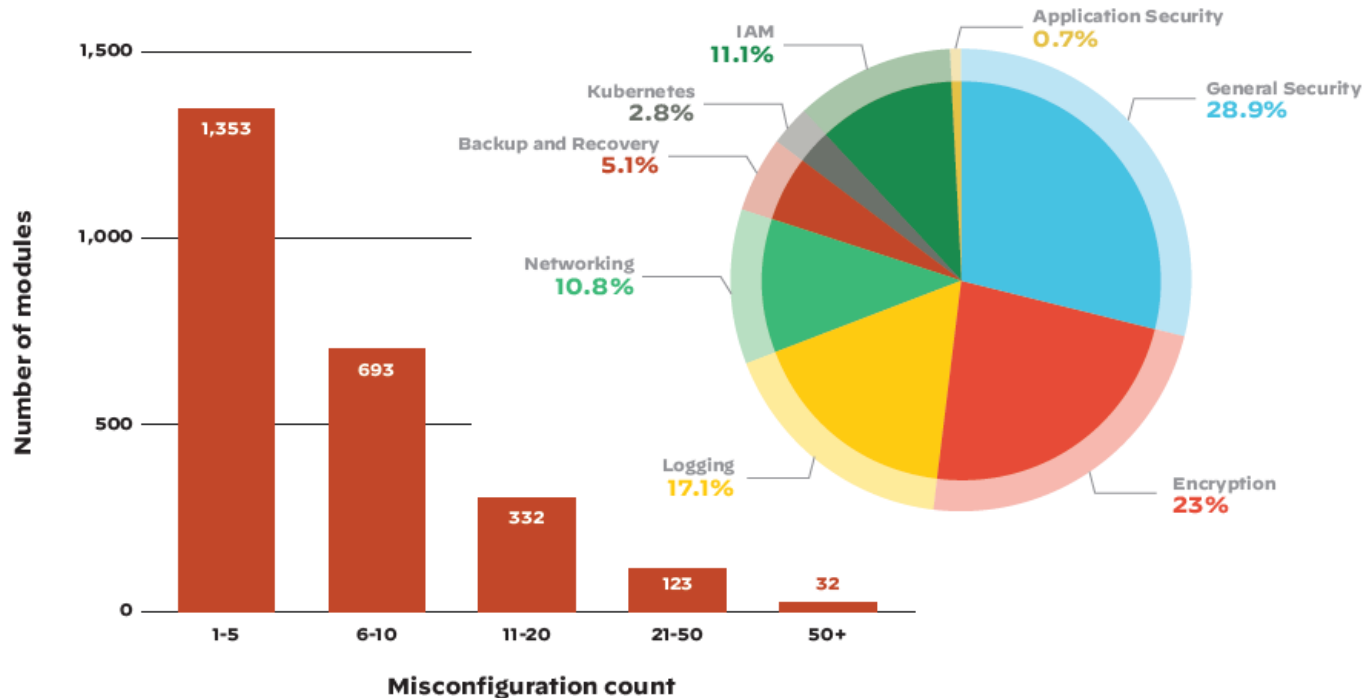


Figure 4: Public Terraform modules by number of misconfigurations (left); types of misconfigurations and their percentages (right)

Source of misconfiguration

Security Teardown: Kubernetes Helm Charts

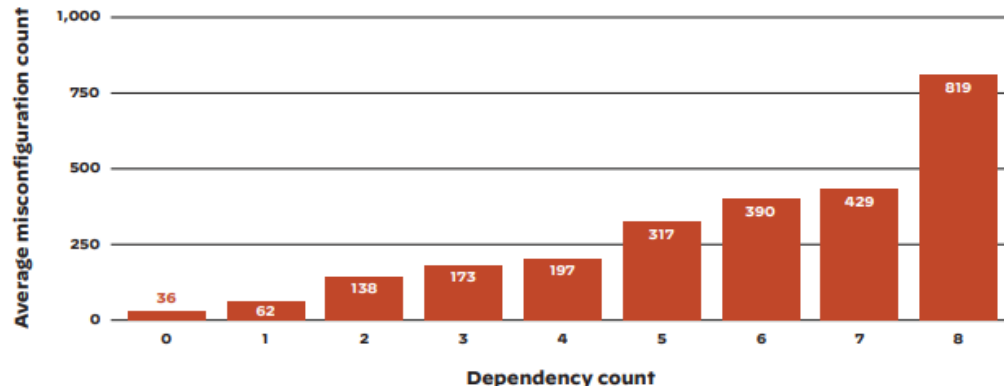
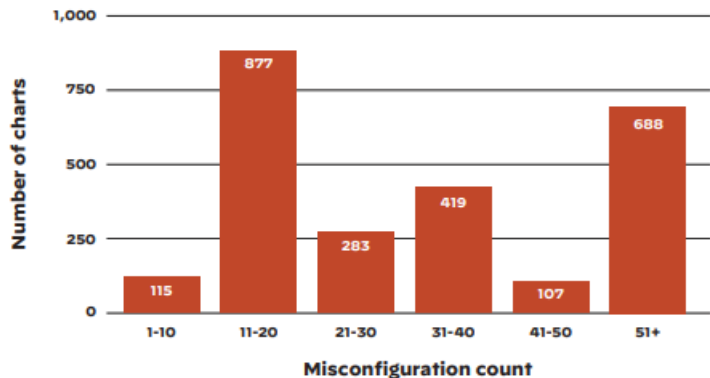
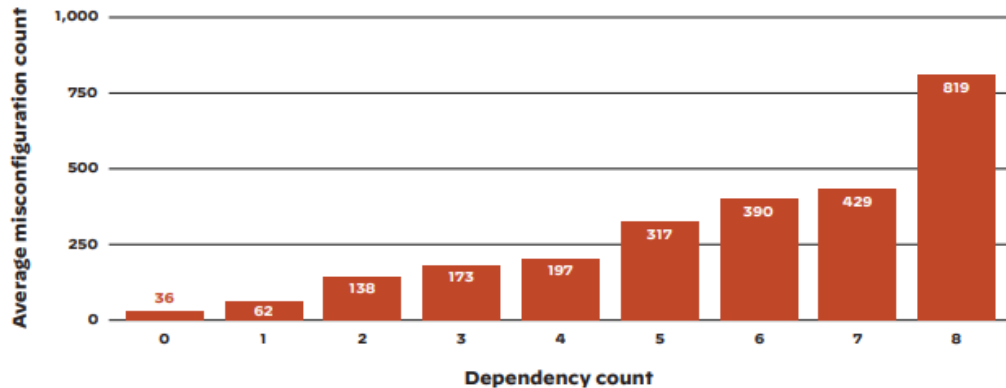
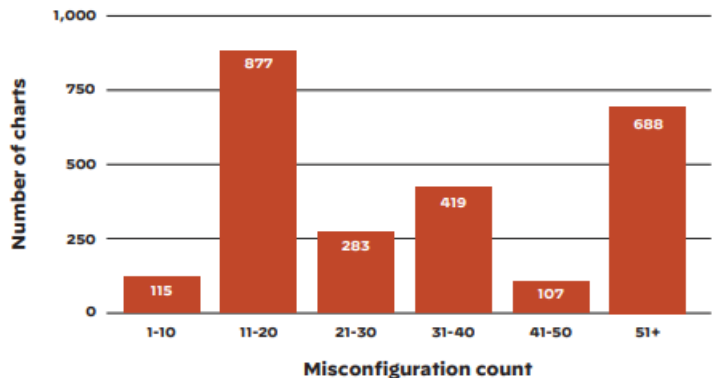


Figure 5: Kubernetes Helm charts categorized by number of misconfigurations they contain (top); average number of misconfigurations for Helm charts with different numbers of dependencies (bottom)

Source of misconfiguration

Security Teardown: Kubernetes Helm Charts



103

Checkov checks
leveraged

2,312

Helm charts
scanned

618

Helm repositories
scanned

6,299

Kubernetes template
files scanned

Figure 5: Kubernetes Helm charts categorized by number of misconfigurations they contain (top); average number of misconfigurations for Helm charts with different numbers of dependencies (bottom)

Source of misconfiguration

Security Teardown: Kubernetes Helm Charts

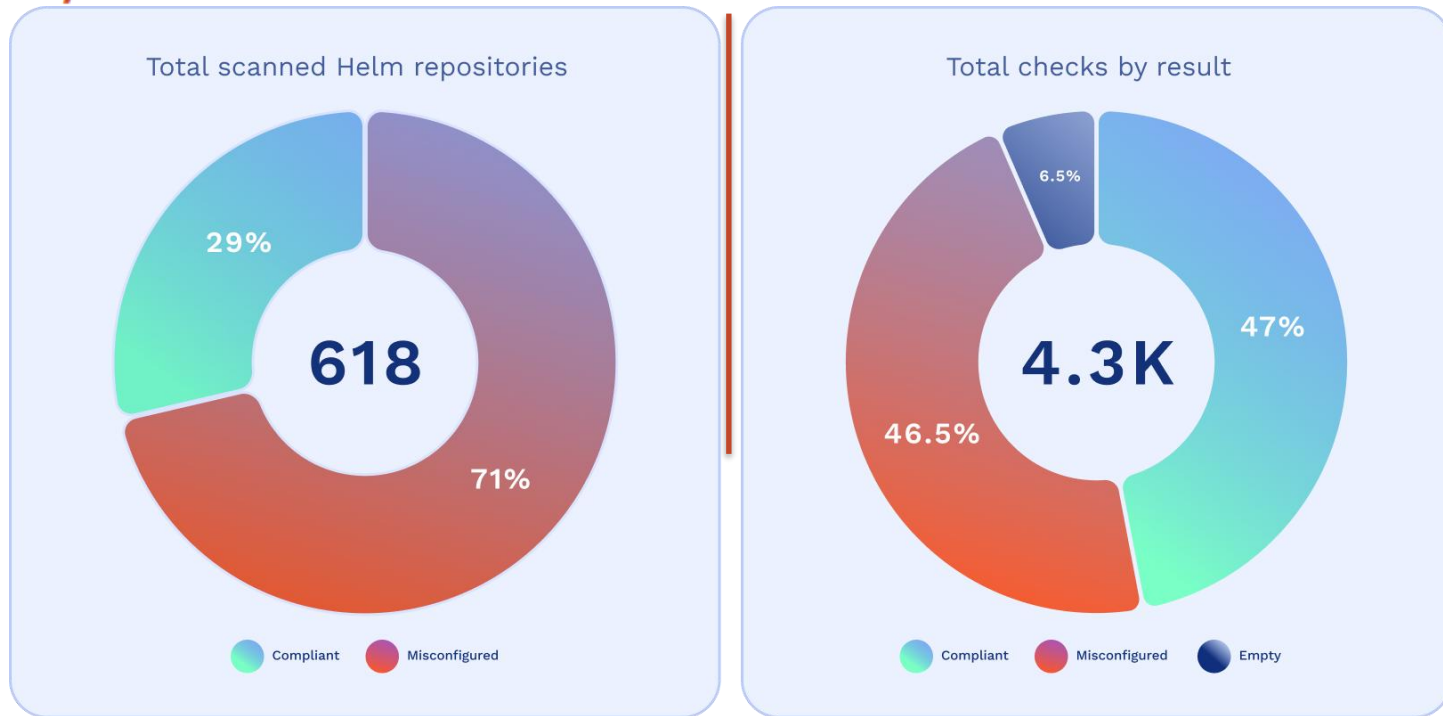


Figure 5: Kubernetes Helm charts categorized by number of misconfigurations they contain (top); average number of misconfigurations for Helm charts with different numbers of dependencies (bottom)

Source of misconfiguration

Security Teardown: Container Images

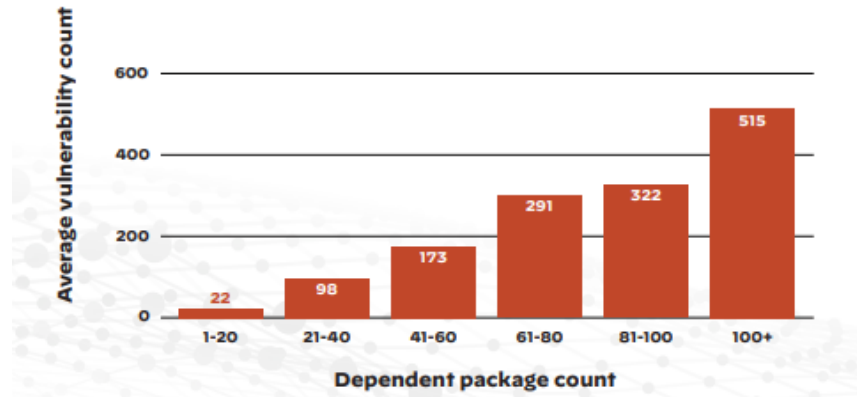
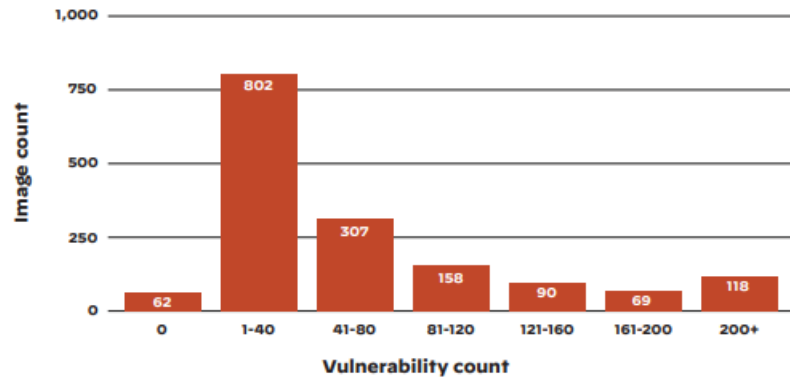
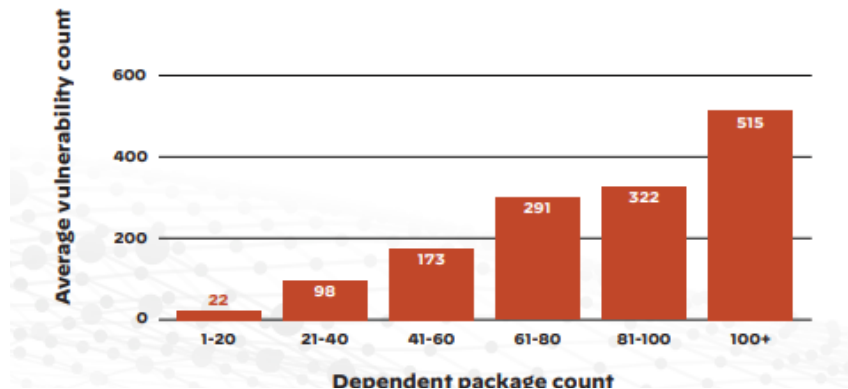
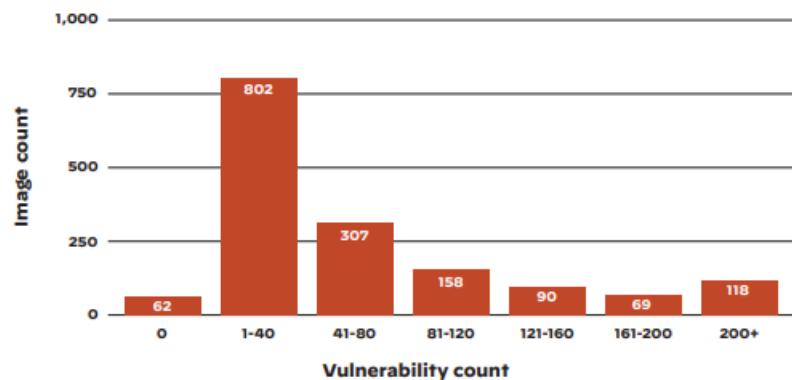


Figure 6: Container images categorized by the number of vulnerabilities they contain (top); vulnerability count of container images with different numbers of dependent packages (bottom)

Source of misconfiguration

Security Teardown: Container Images



What can we do about it ?

Figure 6: Container images categorized by the number of vulnerabilities they contain (top); vulnerability count of container images with different numbers of dependent packages (bottom)

1

2

3

Prisma Cloud



1

OPA ecosystem



2



Styra DAS



Conftest



Scalr



Spacelift



Atmos



Terraform Cloud

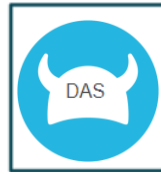
3

Prisma Cloud



1

OPA ecosystem



Styra DAS



Conftest



Scalr



Spacelift



Atmos



Terraform Cloud

2

Terraform ecosystem



Terrascan



Tfsec



Trivy



Terraform-compliance

3

Prisma Cloud



1

OPA ecosystem



Styra DAS



Conftest



Scalr



Spacelift



Atmos



Terraform Cloud

2

Terraform ecosystem



Terrascan



Tfsec



Trivy



Terraform-compliance

3

Prisma Cloud





Open source, **misconfiguration scanner for IaC** with CI/CD support



Open source, **misconfiguration scanner for IaC** with CI/CD support

In a nutshell:

1. **3700+** built in policies (**2k+** terraform)
2. Secrets and credentials detection
3. Supports extensions (Git platforms, Terraform Cloud,...)
4. Dependency aware (Graph-mapping)
5. VSCode plugin & Custom policies
6. 38M downloads

Why checkov ?



Open source, **misconfiguration scanner for IaC** with CI/CD support

In a nutshell:

1. **3700+** built in policies (**2k+** terraform)
2. Secrets and credentials detection
3. Supports extensions (Git platforms, Terraform Cloud,...)
4. Dependency aware (Graph-mapping)
5. VSCode plugin & Custom policies
6. 38M downloads

 Alibaba Cloud

Why checkov ?



Open source, **misconfiguration scanner for IaC** with CI/CD support

In a nutshell:

1. **3700+** built in policies (**2k+** terraform)
2. Secrets and credentials detection
3. Supports extensions (Git platforms, Terraform Cloud,...)
4. Dependency aware (Graph-mapping)
5. VSCode plugin & Custom policies
6. 38M downloads

 Alibaba Cloud

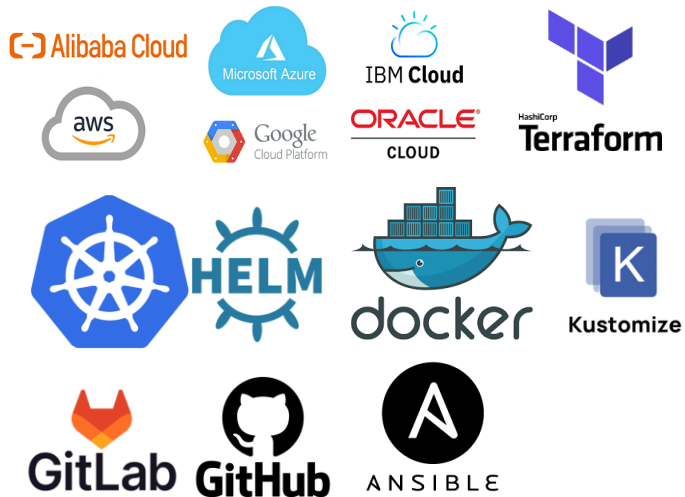
Why checkov ?



Open source, **misconfiguration scanner for IaC** with CI/CD support

In a nutshell:

1. **3700+** built in policies (**2k+** terraform)
2. Secrets and credentials detection
3. Supports extensions (Git platforms, Terraform Cloud,...)
4. Dependency aware (Graph-mapping)
5. VSCode plugin & Custom policies
6. 38M downloads



Why checkov ?

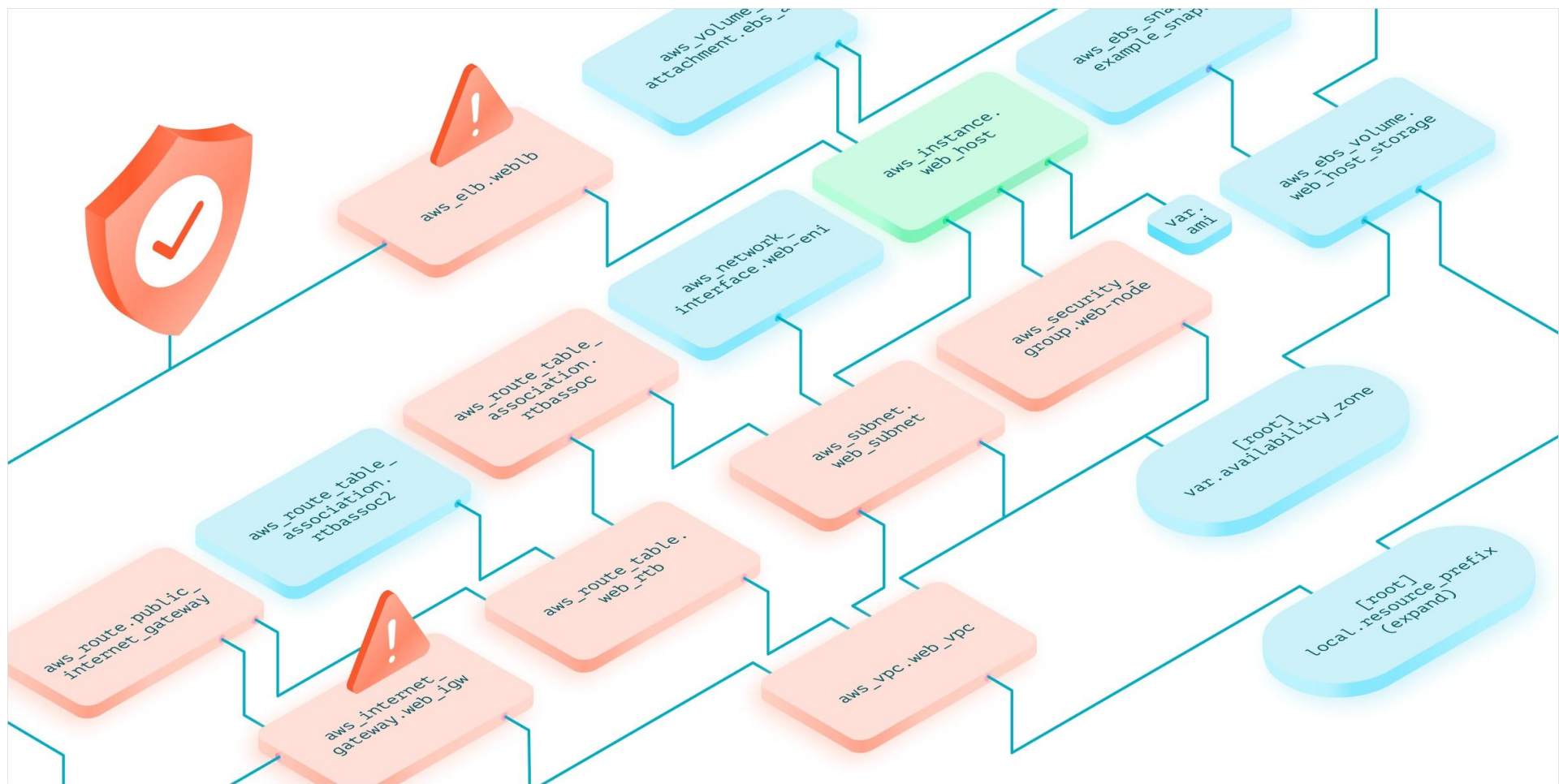


Open source, **misconfiguration scanner for IaC** with CI/CD support

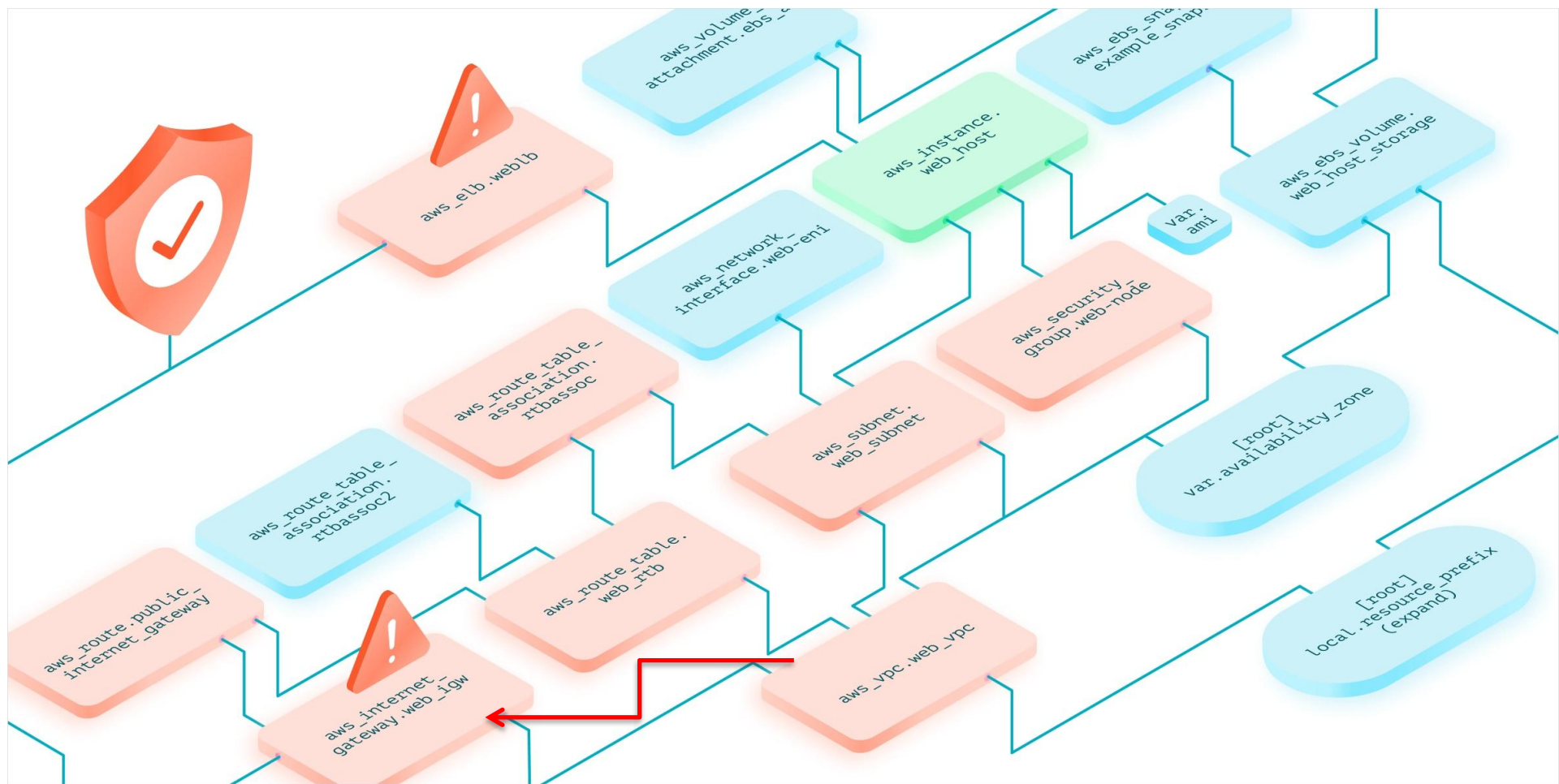
In a nutshell:

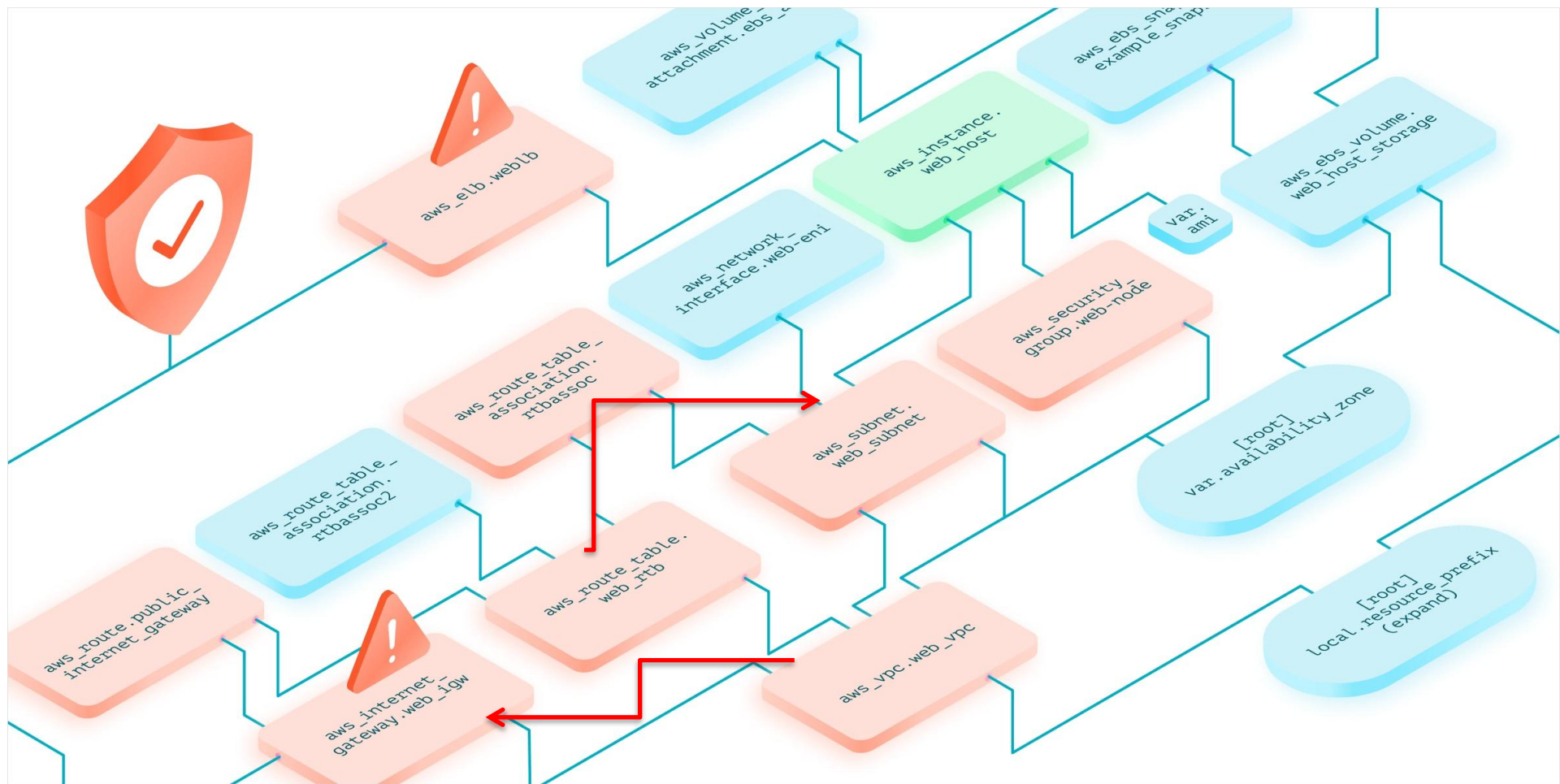
1. **3700+** built in policies (**2k+** terraform)
2. Secrets and credentials detection
3. Supports extensions (Git platforms, Terraform Cloud,...)
4. Dependency aware (Graph-mapping)
5. VSCode plugin & Custom policies
6. 38M downloads



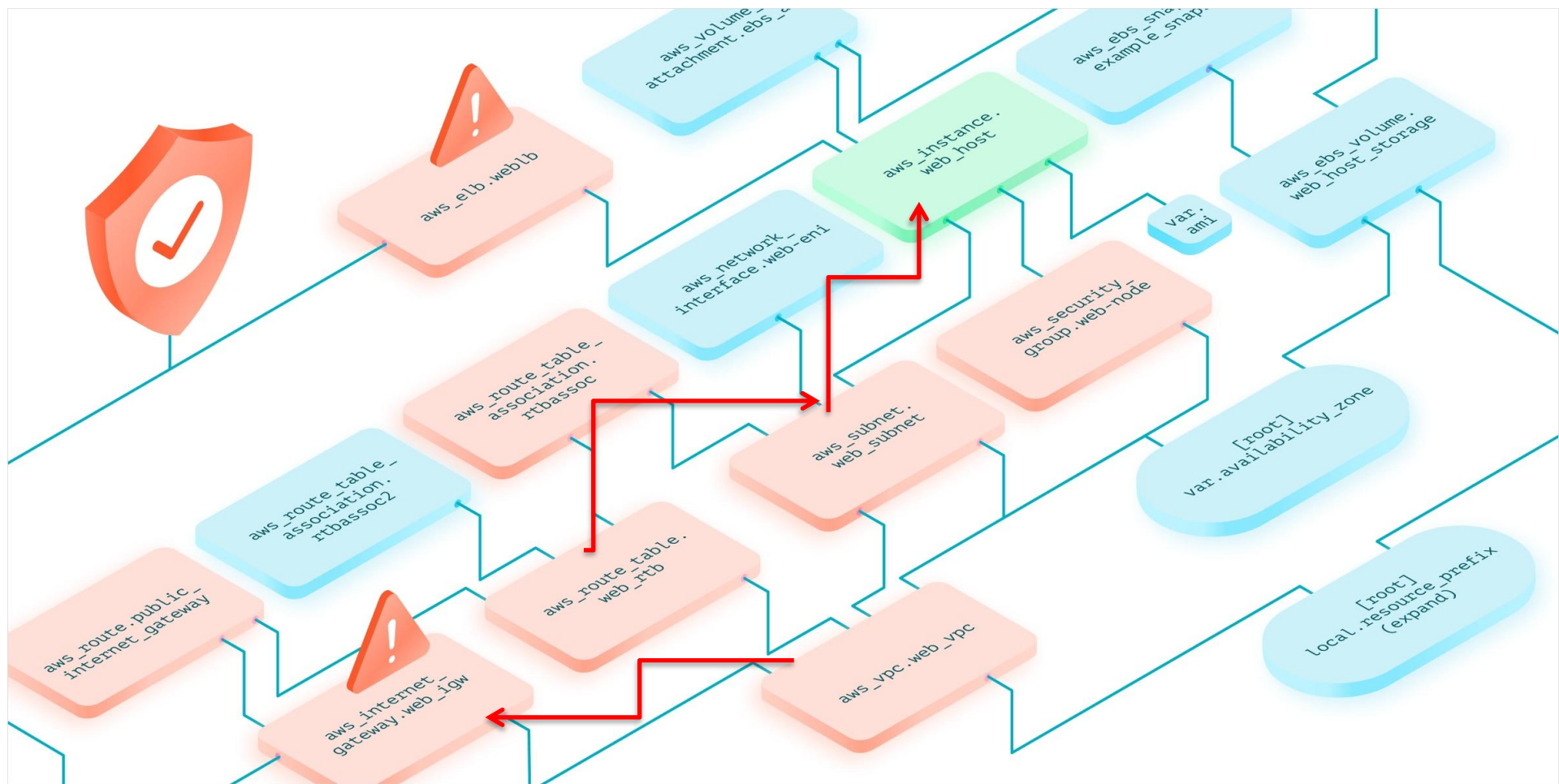


“Revolutionizing Infrastructure Security and Compliance”





“Revolutionizing Infrastructure Security and Compliance”



Config type	File patterns
Kubernetes	<i>.yaml</i> , <i>.yaml</i> , <i>*.json</i>
Docker	<i>*.Dockerfile</i> , <i>Dockerfile.*</i> , <i>Containerfile</i>
Terraform	<i>.tf</i> , <i>.tf.json</i> , <i>*.tfvars</i> , Terraform Plan (JSON/Snapshot)
CloudFormation	<i>.yaml</i> , <i>.yaml</i> , <i>*.json</i>
Azure ARM Template	<i>*.json</i>
Helm	<i>.yaml</i> , <i>.tpl</i> , <i>*.tar.gz</i> , etc.

Benefits:

Config type	File patterns
Kubernetes	<i>.yaml</i> , <i>.yaml</i> , <i>*.json</i>
Docker	<i>*.Dockerfile</i> , <i>Dockerfile.*</i> , <i>Containerfile</i>
Terraform	<i>.tf</i> , <i>.tf.json</i> , <i>*.tfvars</i> , Terraform Plan (JSON/Snapshot)
CloudFormation	<i>.yaml</i> , <i>.yaml</i> , <i>*.json</i>
Azure ARM Template	<i>*.json</i>
Helm	<i>.yaml</i> , <i>.tpl</i> , <i>*.tar.gz</i> , etc.

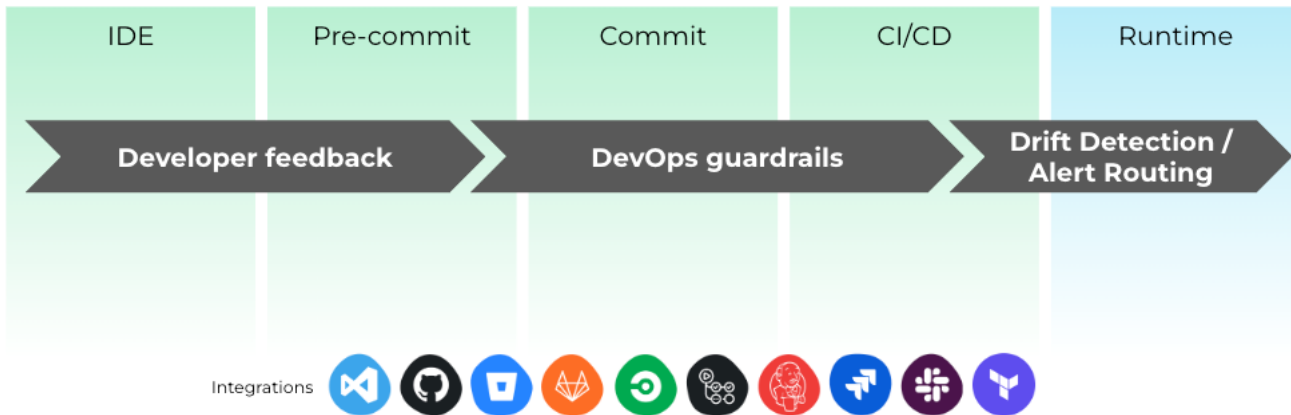
Benefits:

- ❑ Multi-framework/Multi-cloud support and provide ingestible scan data (JUnitXML, sarif)

Config type	File patterns
Kubernetes	<i>.yaml</i> , <i>.yaml</i> , <i>*.json</i>
Docker	<i>*.Dockerfile</i> , <i>Dockerfile.*</i> , <i>Containerfile</i>
Terraform	<i>.tf</i> , <i>.tf.json</i> , <i>*.tfvars</i> , Terraform Plan (JSON/Snapshot)
CloudFormation	<i>.yaml</i> , <i>.yaml</i> , <i>*.json</i>
Azure ARM Template	<i>*.json</i>
Helm	<i>.yaml</i> , <i>.tpl</i> , <i>*.tar.gz</i> , etc.

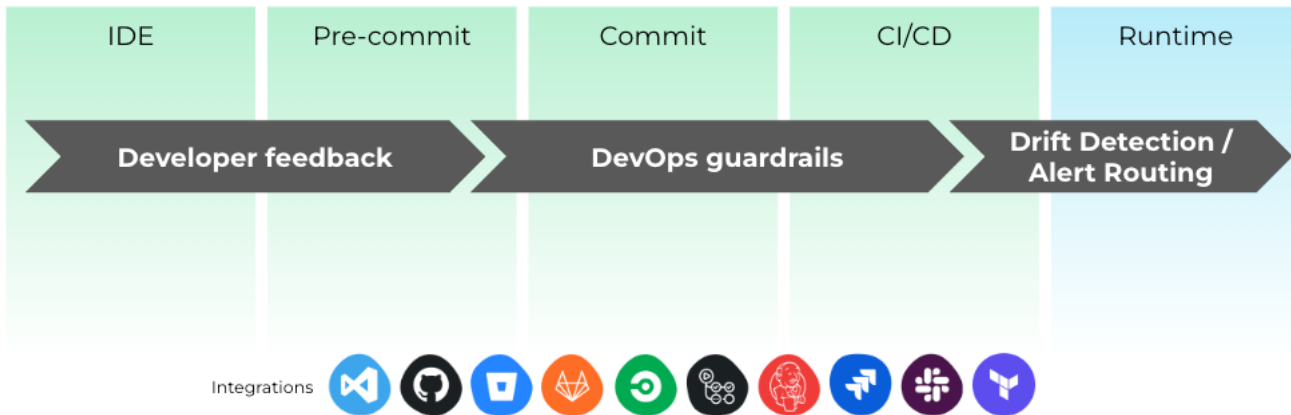
Benefits:

- ❑ Multi-framework/Multi-cloud support and provide ingestible scan data (JUnitXML, sarif)
- ❑ Compliance standards NIST,CIS,HIPAA, SOC2, PCI DSS



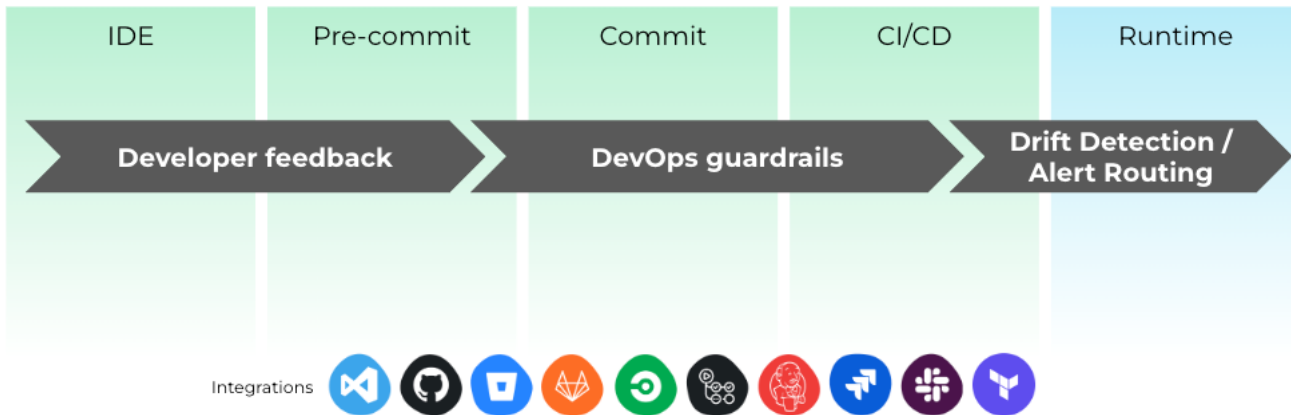
Benefits:

- ❑ Multi-framework/Multi-cloud support and provide ingestible scan data (JUnitXML, sarif)
- ❑ Compliance standards NIST,CIS,HIPAA, SOC2, PCI DSS
- ❑ Seamless CI/CD integration ([Jenkins](#), [Bitbucket](#), [GitHub Actions](#), [GitLab CI](#),etc)



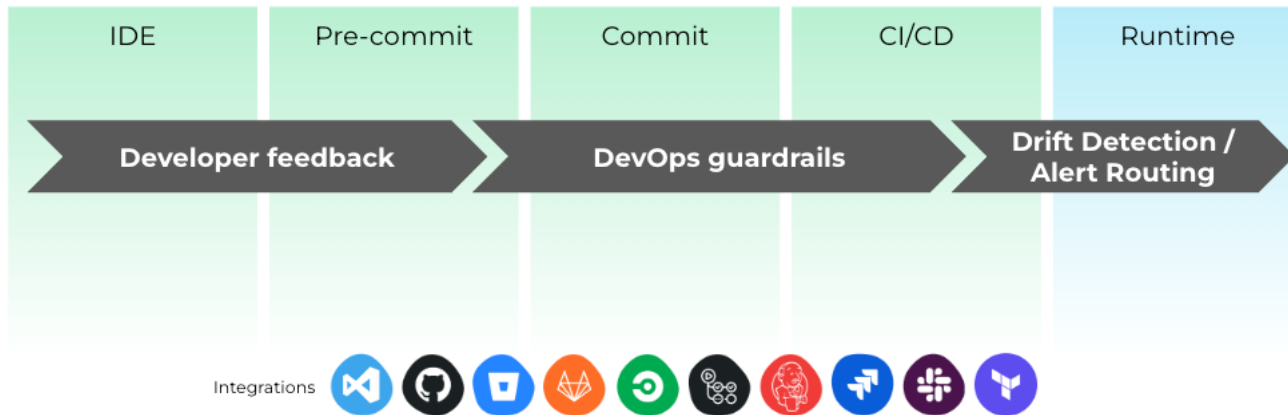
Benefits:

- ❑ Multi-framework/Multi-cloud support and provide ingestible scan data (JUnitXML, sarif)
- ❑ Compliance standards NIST, CIS, HIPAA, SOC2, PCI DSS
- ❑ Seamless CI/CD integration ([Jenkins](#), [Bitbucket](#), [GitHub Actions](#), [GitLab CI](#), etc)
- ❑ VSCode plugin and Pre-commit supports for Early Detection, Continuous Compliance



Benefits:

- ❑ Multi-framework/Multi-cloud support and provide ingestible scan data (JUnitXML, sarif)
- ❑ Compliance standards NIST, CIS, HIPAA, SOC2, PCI DSS
- ❑ Seamless CI/CD integration ([Jenkins](#), [Bitbucket](#), [GitHub Actions](#), [GitLab CI](#), etc)
- ❑ VSCode plugin and Pre-commit supports for Early Detection, Continuous Compliance
- ❑ Integration with OpenAI ChatGPT to enhance checkov's findings



Benefits:

- ❑ Multi-framework/Multi-cloud support and provide ingestible scan data (JUnitXML, sarif)
- ❑ Compliance standards NIST, CIS, HIPAA, SOC2, PCI DSS
- ❑ Seamless CI/CD integration ([Jenkins](#), [Bitbucket](#), [GitHub Actions](#), [GitLab CI](#), etc)
- ❑ VSCode plugin and Pre-commit supports for Early Detection, Continuous Compliance
- ❑ Deep analysis and resolution of Terraform for `_each` and dynamic blocks

Checkov: Installation

❑ Pip or pip3

```
pip3 install checkov
```

❑ Mac

```
brew install checkov
```

❑ Docker

```
docker pull bridgecrew/checkov:latest
```

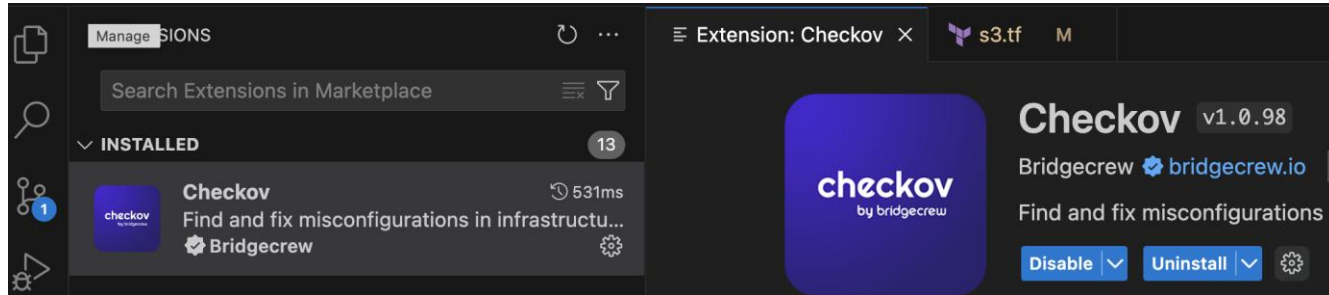
▪ Run Checkov from docker

```
docker run --volume /path/to/terraform/files:/tf bridgecrew/checkov --directory /tf
```


Checkov: VSCode plugin



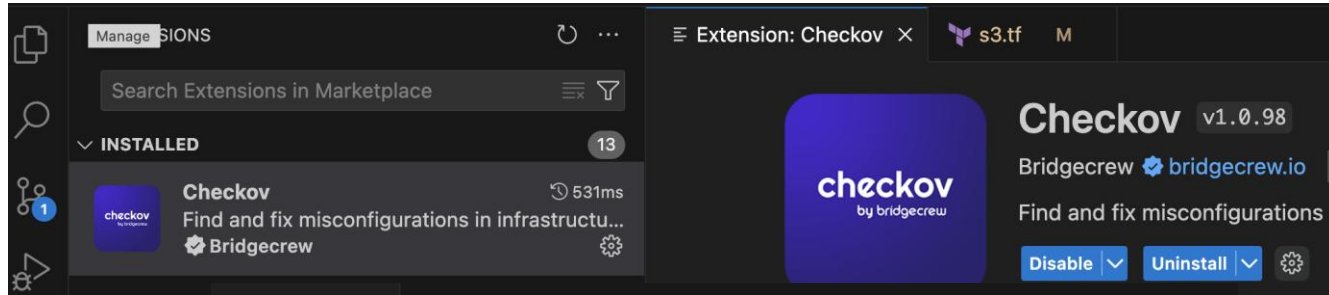
Visual Studio Code



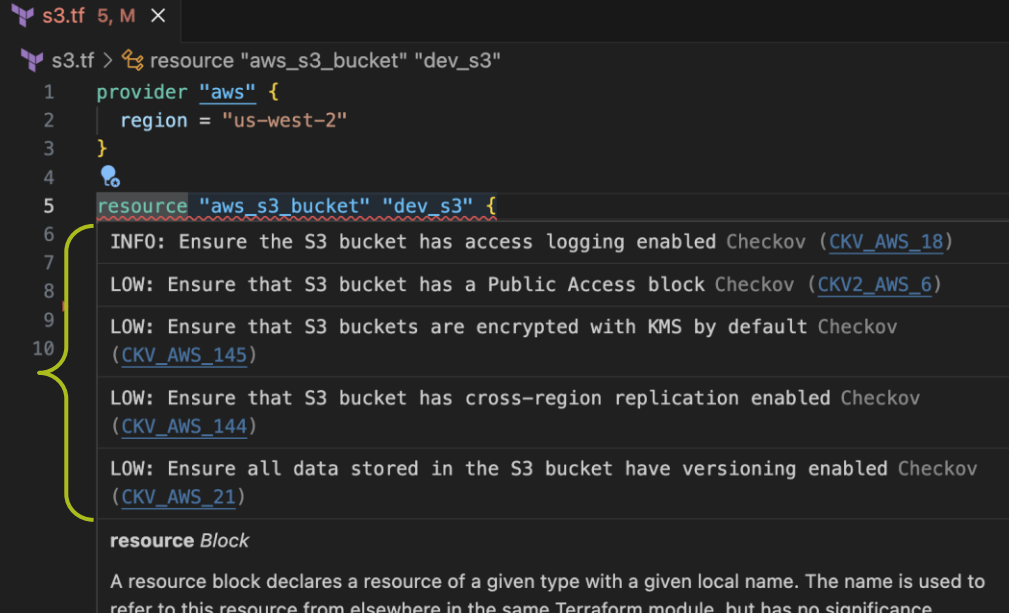
Checkov: VSCode plugin



Visual Studio Code



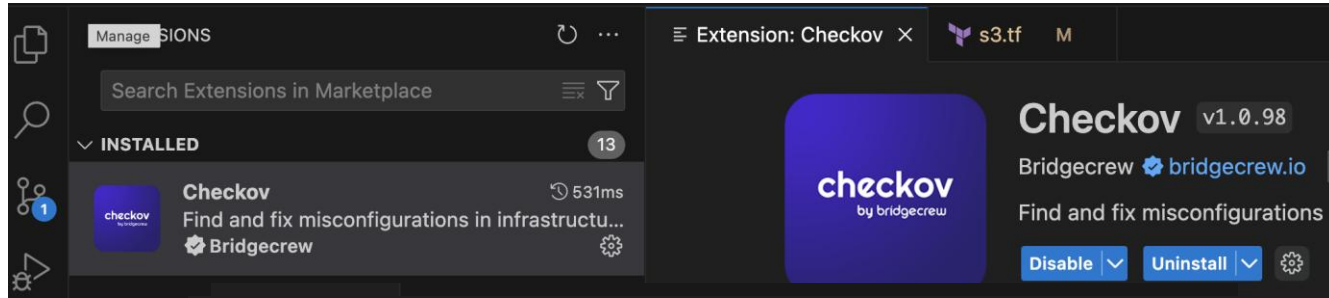
Contextual Display



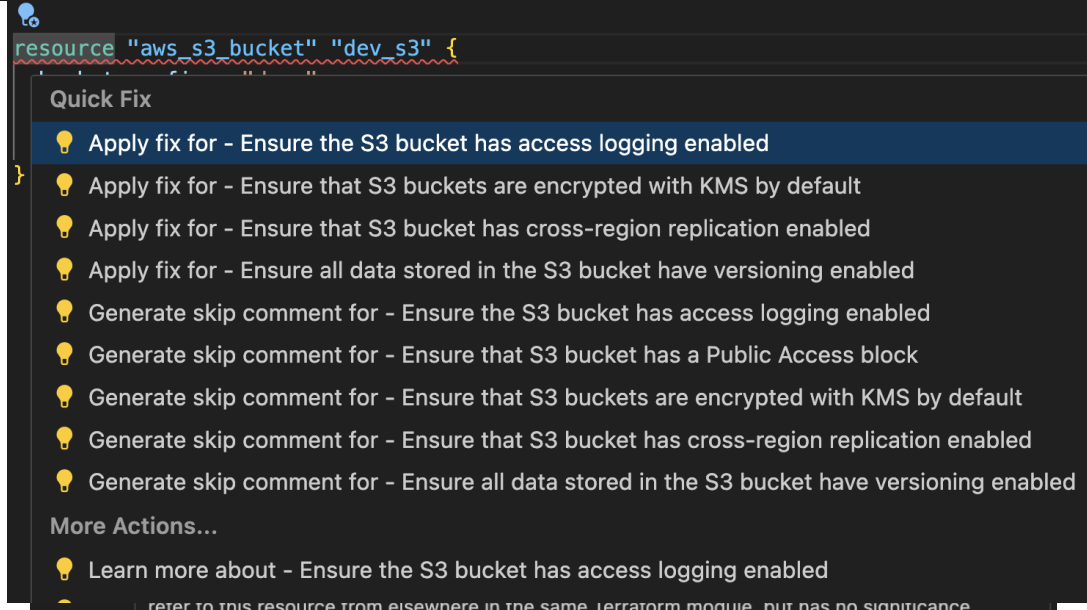
Checkov: VSCode plugin



Visual Studio Code



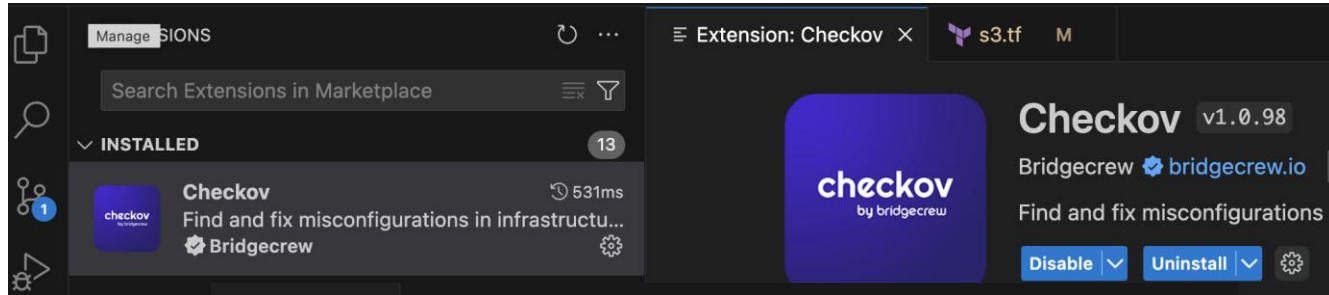
Fix/skip suggestion



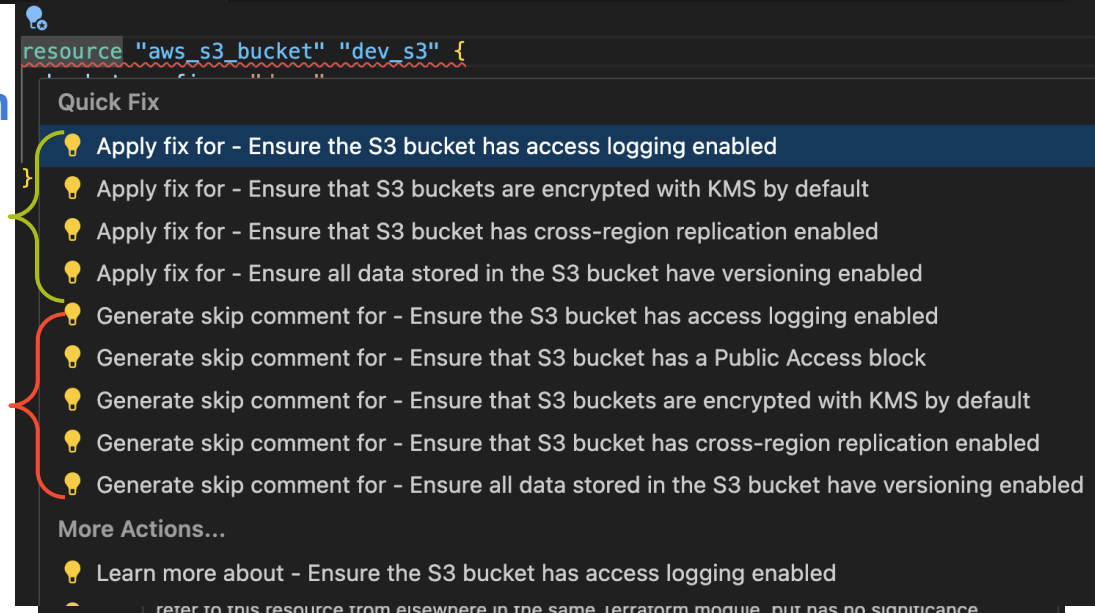
Checkov: VSCode plugin



Visual Studio Code



Fix/skip suggestion



Commands

```
brokedba@brokdaba:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c-check]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA_CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]
```

Infrastructure as code static analysis

options:

- `-h, --help` show this help message and **exit**
- `-v, --version` version
- `--support` Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
- `-d DIRECTORY, --directory DIRECTORY` Iac root directory (can not be used together with `--file`).
- `--add-check` Generate a new check via CLI prompt
- `-f FILE [FILE ...], --file FILE [FILE ...]` File to scan (can not be used together with `--directory`). With this option, Checkov will attempt to filter the

runners

based on the file type. For example, if you specify a `".tf"` file, only the terraform and secrets frameworks will be included. You can further limit this (e.g., skip secrets) by using the `--skip-framework` argument.

- `--skip-path SKIP_PATH` Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word boundaries are not implicit; i.e., specifying `"dir1"` will skip any directory or subdirectory named `"dir1"`. Ignored with `-f`. Can be specified multiple times.
- `--external-checks-dir EXTERNAL_CHECKS_DIR` Directory *for* custom checks to be loaded. Can be repeated
- `--external-checks-git EXTERNAL_CHECKS_GIT` Github url of external checks to be added. you can specify a subdirectory after a double-slash `//`, possible to use `?ref=tags/tagName` or `?ref=heads/branchName` or `?ref=commit_id` cannot be used together with `--external-checks-dir`
- `-l, --list` List checks
- `-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}` Report output format. Add multiple outputs by using the flag multiple times (`-o sarif -o cli`)
- `--output-file-path OUTPUT_FILE_PATH` Name of the output folder to save the chosen output formats. Advanced usage: By using `-o cli -o junitxml --output-file-path console,results.xml` the CLI output will be printed to the console and the JUnitXML output to the file `results.xml`.
- `--output-bc-ids` Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
- `--include-all-checkov-policies` When running with an API key, Checkov will omit any policies that *do not exist* in Prisma Cloud platform, except *for* local custom policies loaded with the `--external-check` flags. Use this key to include policies that *only exist* in Checkov *in* the scan. Note that this will make the local CLI results different from the results you see *in* the platform. Has no effect if you are not using an API key. Use the `--check` option to explicitly include checks by ID even if they are not *in* the platform, without using this flag.
- `--quiet` In case of CLI output, display only failed checks. Also disables progress bars
- `--compact` In case of CLI output, *do not* display code blocks
- `--framework FRAMEWORK ...` Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly include *all* as a value, *then* all other values are ignored. Enter as a comma-separated list or repeat the flag multiple times. For example, `--framework terraform,sca` package or `--framework terraform --framework sca` package. Possible values: `all, ansible, argo_workflows, arm, azure.pipelines, bicep, bitbucket.pipelines, cdk, circleci.pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration, gitlab_ci,`

`bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets, serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy` [env var: CKV_FRAMEWORK]

- `--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]`

Commands

-d --directory

laC root directory to scan

```
brokedba@brokdb:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [-c CHECK]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          version
  --support             Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  -d DIRECTORY, --directory DIRECTORY
                        laC root directory (can not be used together with --file).
  --add-check           Generate a new check via CLI prompt
  -f FILE [FILE ...], --file FILE [FILE ...]
                        File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
runners
                        based on the file type. For example, if you specify a ".tf" file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.
  --skip-path SKIP_PATH
                        Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying "dir1" will skip any directory or subdirectory named "dir1". Ignored
                        with -f. Can be specified multiple times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //. possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
  -l, --list            List checks
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}, --output
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console,results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml.
  --output-bc-ids       Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include all as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform,sca package or --framework terraform --framework sca package.
                        Possible values: all, ansible, argo_workflows, arm, azure_pipelines, arm, azure_pipelines, bicep, bitbucket_pipelines, cdk,
                        circleci_pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```

Commands

-d --directory

IaC root directory to scan

-f --file

File to scan

```
brokedba@brokedba:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c-check]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             IaC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check           File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        based on the file type. For example, if you specify a ".tf" file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.

runners
  --skip-path SKIP_PATH Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying "dir1" will skip any directory or subdirectory named "dir1". Ignored
                        with -f. Can be specified multiple times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //. possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
  -l, --list            List checks
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console,results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml.
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check-check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform,sca package or --framework terraform --framework sca package.
                        Possible values: all, ansible, argo_workflows, arm, azure_pipelines, arm, azure_pipelines, bicep, bitbucket_pipelines, cdk,
                        circleci_pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```


Commands

-d --directory

IaC root directory to scan

-f --file

File to scan

--framework

Run only on specific frameworks

```
brokedba@brokdb:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c-check]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             IaC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check            File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        runners
                        based on the file type. For example, if you specify a *.tf file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.
  --skip-path SKIP_PATH
                        Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying 'dir1' will skip any directory or subdirectory named 'dir1'. Ignored
                        with --ca. Can be specified multiple times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //, possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
  -l, --list            List checks
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console,results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml.
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform,sca package or --framework terraform --framework sca package.
                        Possible values: all, ansible, argo_workflows, arm, azure_pipelines, arm, azure_pipelines, bicep, bitbucket_pipelines, cdk,
                        circleci_pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```


Commands

-d --directory

laC root directory to scan

-f --file

File to scan

--framework

Run only on specific frameworks

--quiet

display only failed checks

```
brokedba@brokdb:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c-check]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             laC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check           File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        based on the file type. For example, if you specify a ".tf" file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.

runners
  --skip-path SKIP_PATH Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying "dir1" will skip any directory or subdirectory named "dir1". Ignored
                        with --ca. Can be specified multiple times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //, possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
  -l, --list            List checks
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console,results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform,sca package or --framework terraform --framework sca package.
                        Possible values: all, ansible, argo_workflows, arm, azure.pipelines, arm, azure.pipelines, bicep, bitbucket.pipelines, cdk,
                        circleci.pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```

Commands

-d --directory

laC root directory to scan

-f --file

File to scan

--framework

Run only on specific frameworks

--quiet

display only failed checks

--compact

do not display code blocks

```
brokedba@brokedba:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c-check]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             laC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check           File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        based on the file type. For example, if you specify a *.tf file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.

runners
  --skip-path SKIP_PATH Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying 'dir1' will skip any directory or subdirectory named 'dir1'. Ignored
                        with --ca. Can be specified multiple times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //. possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
  -l, --list            List checks
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console,results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform,sca package or --framework terraform --framework sca package.
                        Possible values: all, ansible, argo_workflows, arm, azure.pipelines, arm, azure.pipelines, bicep, bitbucket.pipelines, cdk,
                        circleci.pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket.configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```

Commands

-d --directory

laC root directory to scan

-f --file

File to scan

-c, --check CHECK

scan specific check/severity

--quiet

display only failed checks

--compact

do not display code blocks

```
brokedba@brokedba:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c CHECK]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             laC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check           File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        based on the file type. For example, if you specify a ".tf" file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.

runners
  --skip-path SKIP_PATH Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying "dir1" will skip any directory or subdirectory named "dir1". Ignored
                        with --ca. Can be specified multiple times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //, possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
  -l, --list            List checks
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console,results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...), if the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform,sca package or --framework terraform --framework sca package.
                        Possible values: all, ansible, argo_workflows, arm, azure_pipelines, arm, azure_pipelines, bicep, bitbucket_pipelines, cdk,
                        circleci_pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```

Commands

-d --directory

laC root directory to scan

-f --file

File to scan

-c, --check CHECK

scan specific check/severity

--quiet

display only failed checks

-s, --soft-fail

always returns a 0 exit code

```
brokedba@brokedba:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c CHECK]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top,bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             laC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check           File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        based on the file type. For example, if you specify a ".tf" file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.

runners
  --skip-path SKIP_PATH Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying "dir1" will skip any directory or subdirectory named "dir1". Ignored
                        with --ca. Can be specified multiple times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //, possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
  -l, --list            List checks
  -o {cli,csv,cyclonedx,cyclonedx_json,json,junitxml,github_failed_only,gitlab_sast,sarif,spdx}
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console,results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...), if the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform,sca package or --framework terraform --framework sca package.
                        Possible values: all, ansible, argo_workflows, arm, azure_pipelines, arm, azure_pipelines, bicep, bitbucket_pipelines, cdk,
                        circleci_pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```


Commands

-d --directory

laC root directory to scan

-f --file

File to scan

-c, --check CHECK

scan specific check/severity

--skip-check CHECK

skip listed CHECK

-s, --soft-fail

always returns a 0 exit code

```
brokedba@brokedba:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli, csv, cyclonedx, cyclonedx_json, json, junitxml, github_failed_only, gitlab_sast, sarif, spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               --framework FRAMEWORK [FRAMEWORK ...] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [--c CHECK]
               --skip-check SKIP_CHECK [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               --bc-api-key BC_API_KEY [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               --dockerfile-path DOCKERFILE_PATH [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               --download-external-modules DOWNLOAD_EXTERNAL_MODULES [--var-file VAR_FILE]
               --external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH [--evaluate-variables EVALUATE_VARIABLES]
               --ca CA_CERTIFICATE [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               --config-file CONFIG_FILE [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               --output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               --secrets-scan-file-type SECRETS_SCAN_FILE_TYPE [--enable-secret-scan-all-files]
               --block-list-secret-scan BLOCK_LIST_SECRET_SCAN [--summary-position {top, bottom}] [--skip-resources-without-violations]
               --deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             laC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check            File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        based on the file type. For example, if you specify a ".tf" file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.

runners
  --skip-path SKIP_PATH Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying "dir1" will skip any directory or subdirectory named "dir1". Ignored
                        with --can-be-specified-multiple-times.
  --external-checks-dir EXTERNAL_CHECKS_DIR Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT Github url of external checks to be added. you can specify a subdirectory after a double-slash //, possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
                        List checks
  -l, --list            List checks
  -o {cli, csv, cyclonedx, cyclonedx_json, json, junitxml, github_failed_only, gitlab_sast, sarif, spdx}, --output
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console, results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml.
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet               In case of CLI output, display only failed checks. Also disables progress bars
  --compact             In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform, sca package or --framework terraform --framework sca_package.
                        Possible values: all, ansible, argo_workflows, arm, azure_pipelines, arm, azure_pipelines, bicep, bitbucket_pipelines, cdk,
                        circleci_pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, sca_package, sca_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```

Commands

-d --directory

laC root directory to scan

-l, --list

List checks

-c, --check CHECK

scan specific check/severity

--skip-check CHECK

skip listed CHECK

-s, --soft-fail

always returns a 0 exit code

```
brokedba@brokedba:~$ checkov -h
usage: checkov [-h] [-v] [--support] [-d DIRECTORY] [--add-check] [-f FILE [FILE ...]] [--skip-path SKIP_PATH]
               [--external-checks-dir EXTERNAL_CHECKS_DIR] [--external-checks-git EXTERNAL_CHECKS_GIT] [-l]
               [-o {cli, csv, cyclonedx, cyclonedx_json, json, junitxml, github_failed_only, gitlab_sast, sarif, spdx}]
               [--output-file-path OUTPUT_FILE_PATH] [--output-bc-ids] [--include-all-checkov-policies] [--quiet] [--compact]
               [--framework FRAMEWORK [FRAMEWORK ...]] [--skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]] [-c CHECK]
               [--skip-check SKIP_CHECK] [--run-all-external-checks] [-s] [--soft-fail-on SOFT_FAIL_ON] [--hard-fail-on HARD_FAIL_ON]
               [--bc-api-key BC_API_KEY] [--prisma-api-url PRISMA_API_URL] [--skip-results-upload] [--docker-image DOCKER_IMAGE]
               [--dockerfile-path DOCKERFILE_PATH] [--repo-id REPO_ID] [-b BRANCH] [--skip-download] [--use-enforcement-rules]
               [--download-external-modules DOWNLOAD_EXTERNAL_MODULES] [--var-file VAR_FILE]
               [--external-modules-download-path EXTERNAL_MODULES_DOWNLOAD_PATH] [--evaluate-variables EVALUATE_VARIABLES]
               [--ca CA CERTIFICATE] [--no-cert-verify] [--repo-root-for-plan-enrichment REPO_ROOT_FOR_PLAN_ENRICHMENT]
               [--config-file CONFIG_FILE] [--create-config CREATE_CONFIG] [--show-config] [--create-baseline] [--baseline BASELINE]
               [--output-baseline-as-skipped] [--skip-cve-package SKIP_CVE_PACKAGE] [--policy-metadata-filter POLICY_METADATA_FILTER]
               [--secrets-scan-file-type SECRETS_SCAN_FILE_TYPE] [--enable-secret-scan-all-files]
               [--block-list-secret-scan BLOCK_LIST_SECRET_SCAN] [--summary-position {top, bottom}] [--skip-resources-without-violations]
               [--deep-analysis] [--no-fail-on-crash] [--mask MASK] [--scan-secrets-history]
               [--secrets-history-timeout SECRETS_HISTORY_TIMEOUT] [--openai-api-key OPENAI_API_KEY]

Infrastructure as code static analysis

options:
  -h, --help            show this help message and exit
  -v, --version          Enable debug logs and upload the logs to the server. Requires a Bridgecrew or Prisma Cloud API key.
  --support             laC root directory (can not be used together with --file).
  -d DIRECTORY, --directory DIRECTORY
                        Generate a new check via CLI prompt
  --add-check            File to scan (can not be used together with --directory). With this option, Checkov will attempt to filter the
  -f FILE [FILE ...], --file FILE [FILE ...]
                        based on the file type. For example, if you specify a ".tf" file, only the terraform and secrets frameworks will be
                        included. You can further limit this (e.g., skip secrets) by using the --skip-framework argument.

runners
  --skip-path SKIP_PATH Path (file or directory) to skip, using regular expression logic, relative to current working directory. Word
                        boundaries are not implicit; i.e., specifying "dir1" will skip any directory or subdirectory named "dir1". Ignored
                        with --can-be-specified-multiple-times.
  --external-checks-dir EXTERNAL_CHECKS_DIR
                        Directory for custom checks to be loaded. Can be repeated
  --external-checks-git EXTERNAL_CHECKS_GIT
                        Github url of external checks to be added. you can specify a subdirectory after a double-slash //, possible to use
                        ?ref=tags/tagName or ?ref=heads/branchName or ?ref=commit_id cannot be used together with --external-checks-dir
                        List checks
  -l, --list            -o {cli, csv, cyclonedx, cyclonedx_json, json, junitxml, github_failed_only, gitlab_sast, sarif, spdx}
                        Report output format. Add multiple outputs by using the flag multiple times (-o sarif -o cli)
  --output-file-path OUTPUT_FILE_PATH
                        Name of the output folder to save the chosen output formats. Advanced usage: By using -o cli -o junitxml --output-
                        file-path console, results.xml the CLI output will be printed to the console and the JUnitXML output to the file
                        results.xml.
  --output-bc-ids        Print Bridgecrew platform IDs (BC...) instead of Checkov IDs (CKV...). If the check exists in the platform
  --include-all-checkov-policies
                        When running with an API key, Checkov will omit any policies that do not exist in Prisma Cloud platform, except for
                        local custom policies loaded with the --external-check flags. Use this key to include policies that only exist in
                        Checkov in the scan. Note that this will make the local CLI results different from the results you see in the
                        platform. Has no effect if you are not using an API key. Use the --check option to explicitly include checks by ID
                        even if they are not in the platform, without using this flag.
  --quiet              In case of CLI output, display only failed checks. Also disables progress bars
  --compact            In case of CLI output, do not display code blocks
  --framework FRAMEWORK [FRAMEWORK ...]
                        Filter scan to run only on specific infrastructure as code frameworks. Defaults to all frameworks. If you explicitly
                        include 'all' as a value, then all other values are ignored. Enter as a comma-separated list or repeat the flag
                        multiple times. For example, --framework terraform, s3a_package or --framework terraform --framework s3a_package.
                        Possible values: all, ansible, argo_workflows, arm, azure_pipelines, arm, azure_pipelines, bicep, bitbucket_pipelines, cdk,
                        circleci_pipelines, cloudformation, dockerfile, github_configuration, github_actions, gitlab_configuration,
                        gitlab_ci,
                        bitbucket_configuration, helm, json, yaml, kubernetes, kustomize, openapi, s3a_package, s3a_image, secrets,
                        serverless, terraform, terraform_json, terraform_plan, sast, sast_python, sast_java, sast_javascript, 3d_policy [env
                        var: CKV_FRAMEWORK]
  --skip-framework SKIP_FRAMEWORK [SKIP_FRAMEWORK ...]
```

Checkov: Baselines and custom policies

❑ Baselines

Purpose: Set a baseline to skip existing misconfigurations in future scans.

- **Create a Baseline:**



```
checkov -d path/to/directory --create-baseline
```

- **Use the Baseline for Future Scans:**



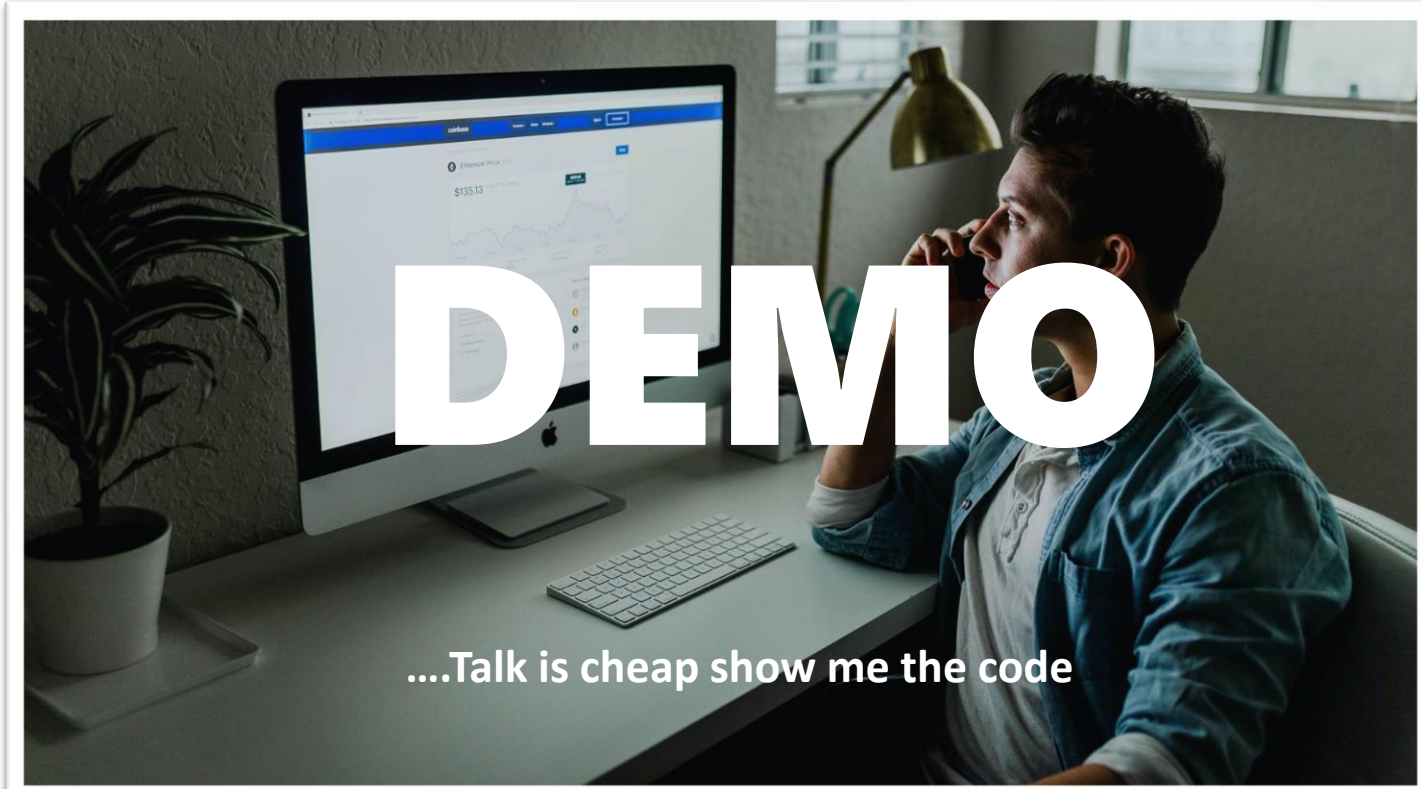
```
checkov -d path/to/directory --baseline path/to/directory/.checkov.baseline
```


Checkov: Baselines and custom policies

❑ Custom Policies (yaml,python)

```
---
metadata:
  name: "Ensure all modules are using the official AWS ones"
  id: "CKV2_AWS_1"
  category: "SUPPLY_CHAIN"
definition:
  cond_type: attribute
  resource_types:
    - module
  attribute: source
  operator: starting_with
  value: terraform-aws-modules
```

Checkov CLI

A man in a blue shirt is sitting at a desk, talking on a mobile phone. He is looking at a computer monitor that displays a website with a line graph. The word "DEMO" is overlaid in large white letters across the center of the image.

DEMO

....Talk is cheap show me the code

Shift left with Checkov in CI/CD



❑ Integration with CI pipelines overview

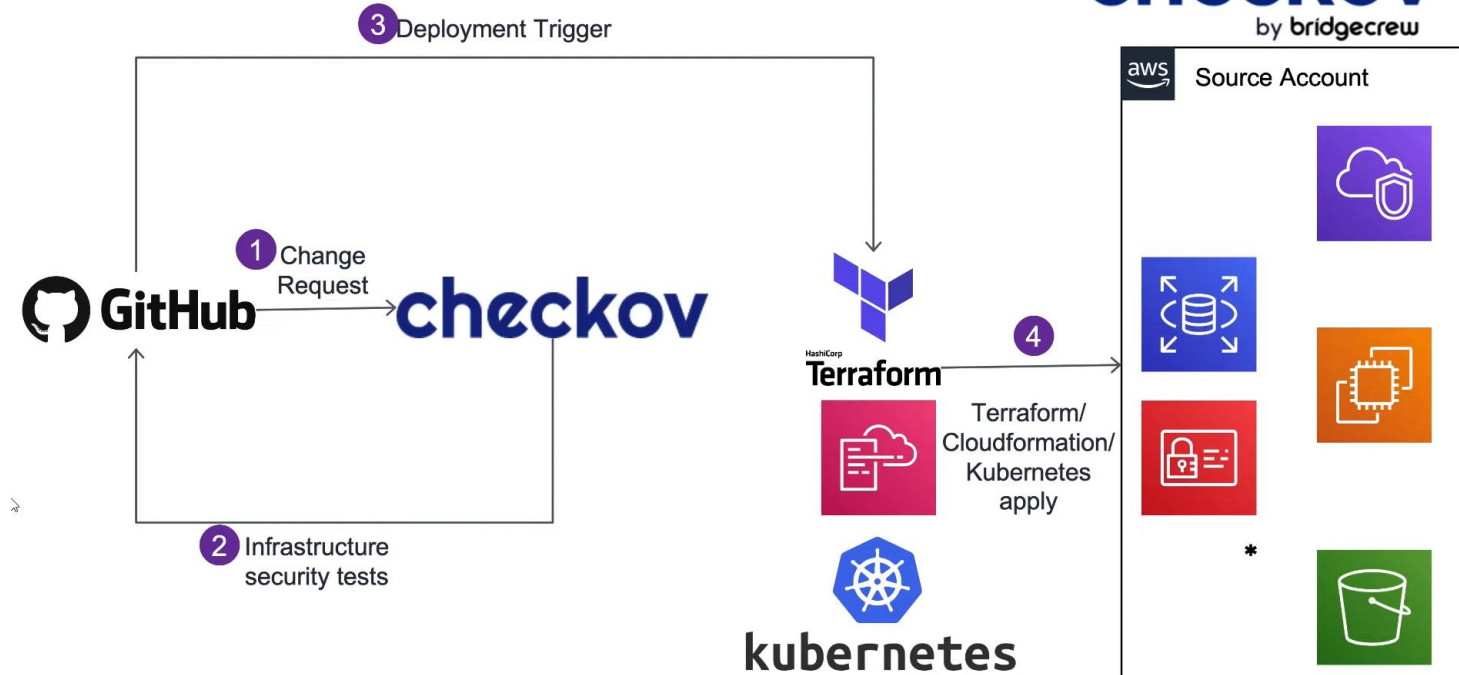


Shift left with Checkov in CI/CD



Integration with CI pipelines overview

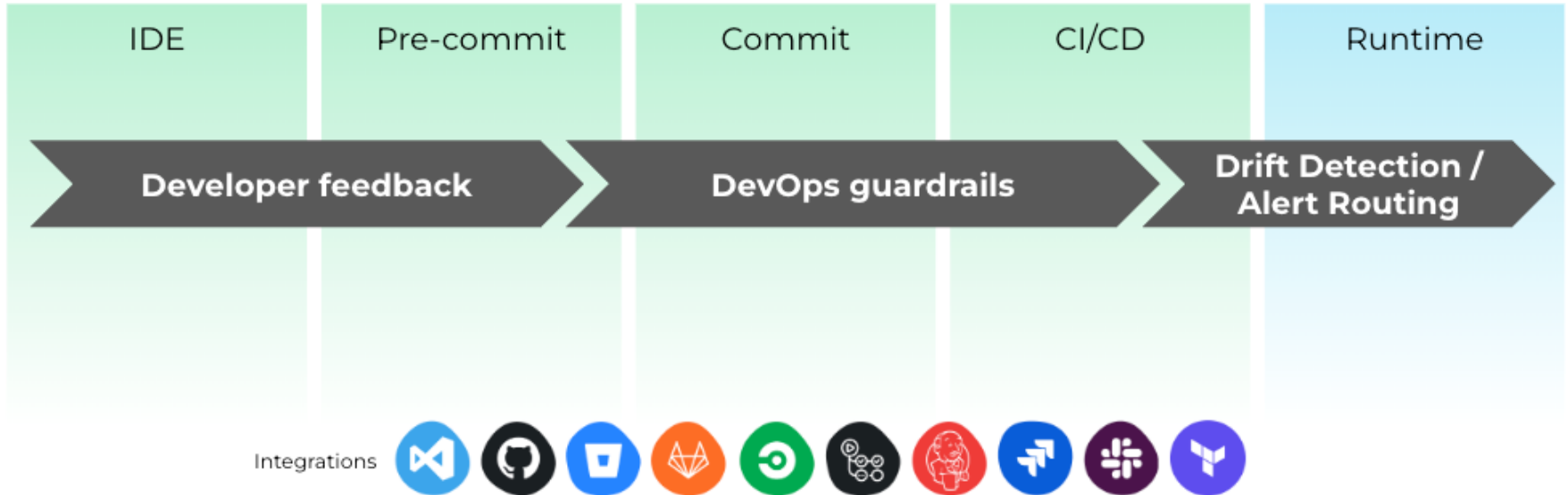
Checkov: Designed for CI



Shift left with Checkov in CI/CD



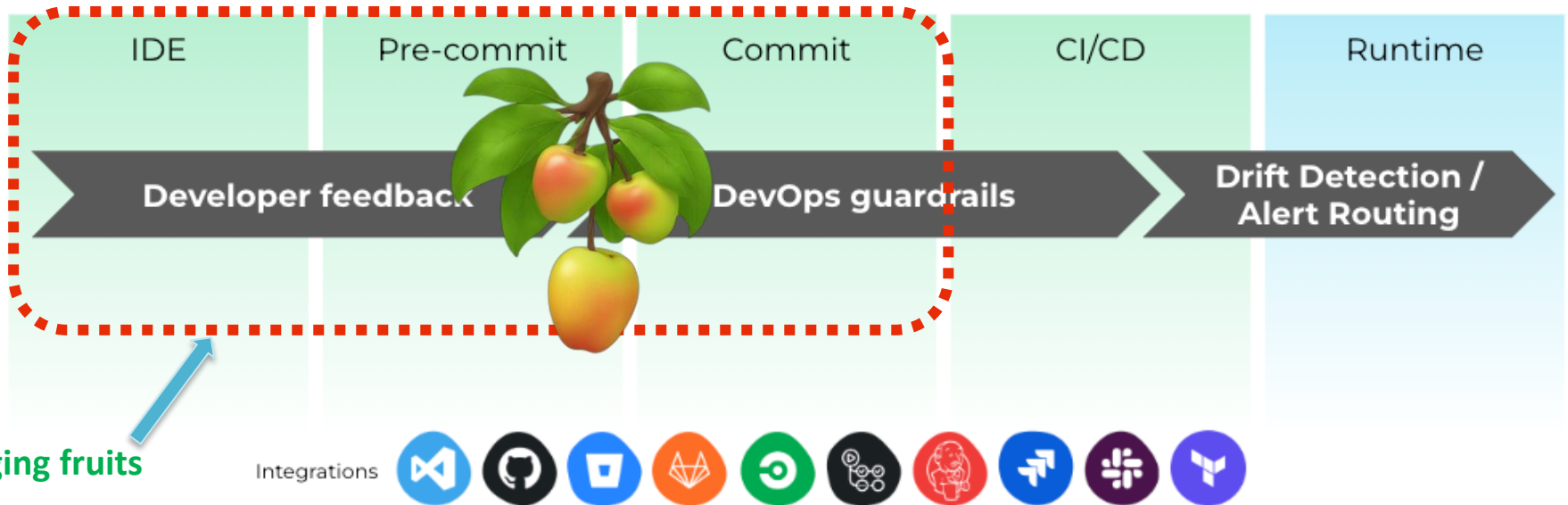
Integration with CI pipelines overview



Shift left with Checkov in CI/CD

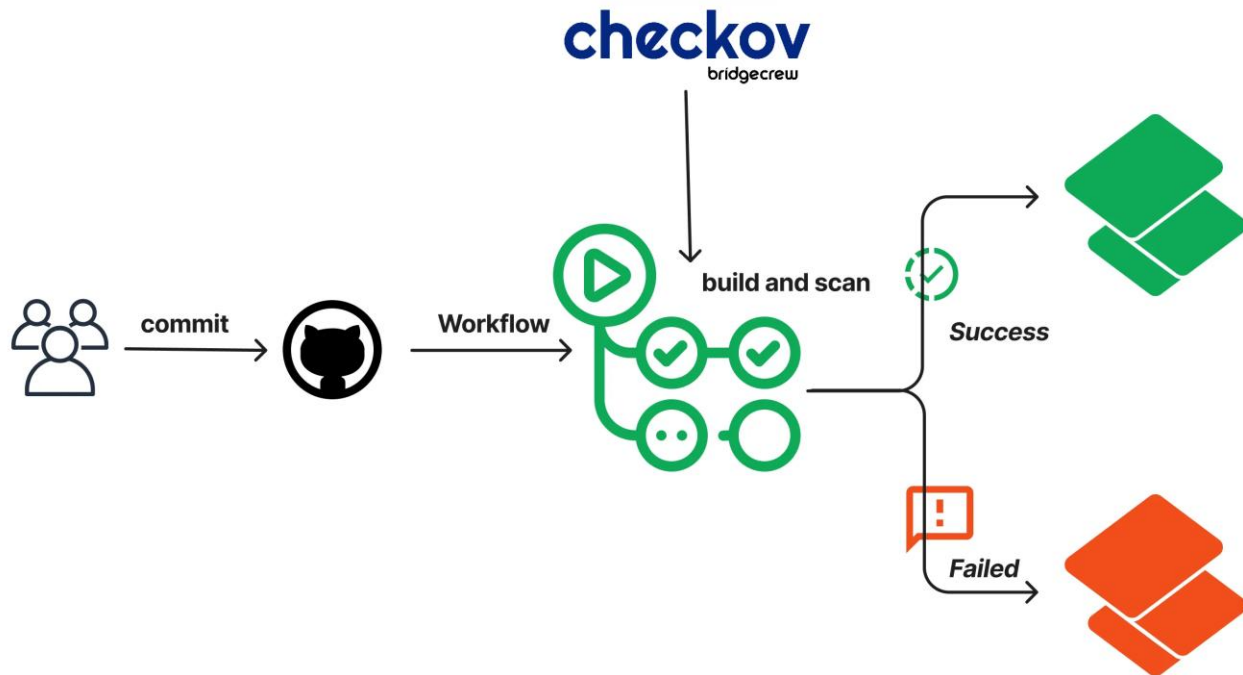


Integration with CI pipelines overview



Pretty HTML report – GitHub Actions

Output: Sarif



Pretty HTML report – GitHub Actions

 Search or jump to... Pull requests Issues Marketplace Explore

schosterbarak / sarif-demo3 Watch 1

<> Code Pull requests Actions Projects Wiki Security 65 Insights Settings

Overview

Reporting

Policy

Advisories

Vulnerability alerts

Dependabot

Code scanning 65

Secret scanning

Code scanning

✖ checkov is reporting errors

Tool status 1 + Add tool

Q is:open branch:main

☐ 65 Open 0 Closed

Language Tool Branch Rule Severity Sort

☐ **Base64 High Entropy String** Error main

#65 opened 50 minutes ago • Detected by checkov in code/deployment_ec2.tf:16

☐ **AWS Access Key** Error main

#64 opened 50 minutes ago • Detected by checkov in code/deployment_ec2.tf:15

☐ **Ensure that a user for the container has been created** Error main

#63 opened 50 minutes ago • Detected by checkov in code/Dockerfile:1

☐ **Ensure that HEALTHCHECK instructions have been added to container images** Error main

#62 opened 50 minutes ago • Detected by checkov in code/Dockerfile:1

☐ **Ensure that APT isn't used** Error main

#61 opened 50 minutes ago • Detected by checkov in code/Dockerfile:4

☐ **Ensure that only encrypted EBS volumes are attached to EC2 instances** Error main

#60 opened 50 minutes ago • Detected by checkov in code/deployment_ec2.tf:23

☐ **Ensure S3 buckets should have event notifications enabled** Error main

#59 opened 50 minutes ago • Detected by checkov in code/simple_s3.tf:5

Pretty HTML report – GitHub Actions

Search or jump to... Pull requests Issues Marketplace Explore

schosterbarak / sarif-demo3

<> Code Pull requests Actions Projects Wiki Security 65 Insights Settings

Overview

Reporting

Policy

Advisories

Vulnerability alerts

Dependabot

Code scanning 65

Secret scanning

Code scanning

checkov is reporting errors

Tool status 1 + Add tool

is:open branch:main

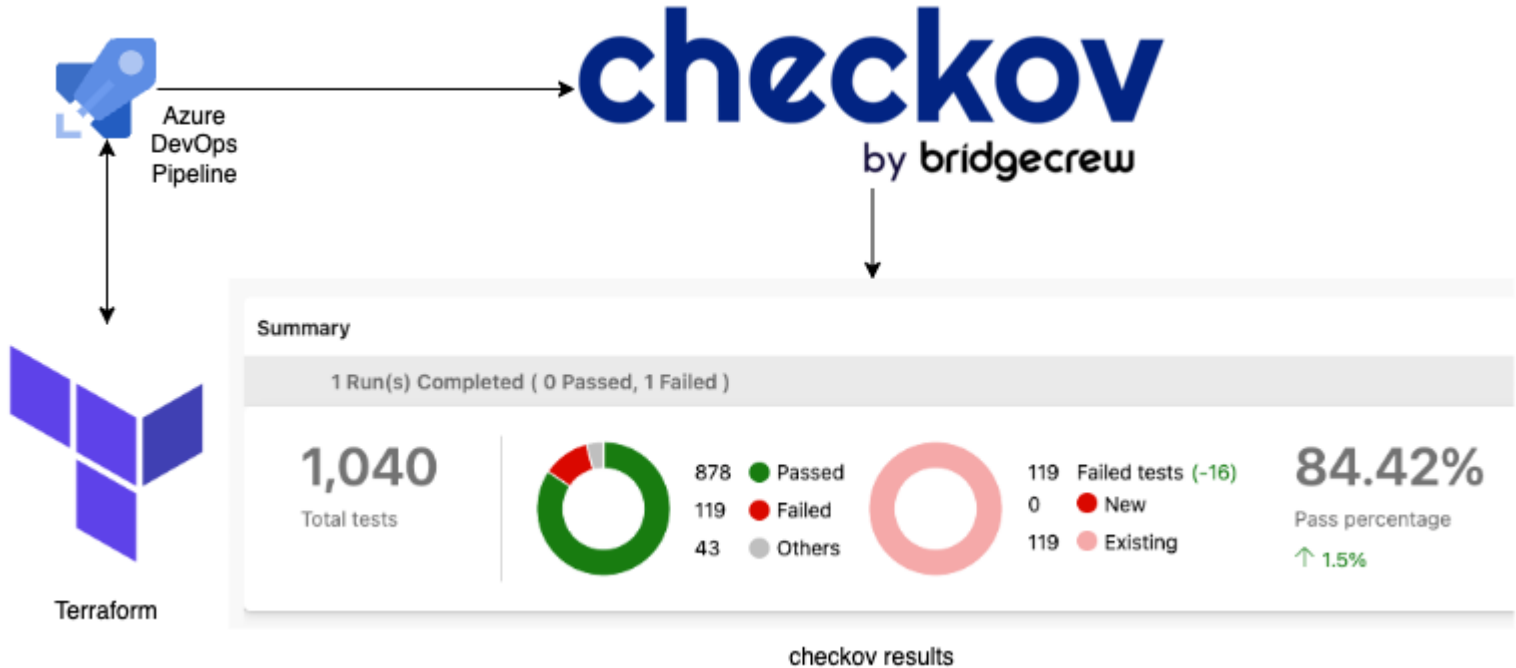
65 Open 0 Closed

	Language	Tool	Branch	Rule	Severity	Sort
☐ Base64 High Entropy String Error			main			
#65 opened 50 minutes ago · Detected by checkov in code/deployment_ec2.tf:16						
☐ AWS Access Key Error			main			
#64 opened 50 minutes ago · Detected by checkov in code/deployment_ec2.tf:15						
☐ Ensure that a user for the container has been created Error			main			
#63 opened 50 minutes ago · Detected by checkov in code/Dockerfile:1						
☐ Ensure that HEALTHCHECK instructions have been added to container images Error			main			
#62 opened 50 minutes ago · Detected by checkov in code/Dockerfile:1						
☐ Ensure that APT isn't used Error			main			
#61 opened 50 minutes ago · Detected by checkov in code/Dockerfile:4						
☐ Ensure that only encrypted EBS volumes are attached to EC2 instances Error			main			
#60 opened 50 minutes ago · Detected by checkov in code/deployment_ec2.tf:23						
☐ Ensure S3 buckets should have event notifications enabled Error			main			
#59 opened 50 minutes ago · Detected by checkov in code/simple_s3.tf:5						

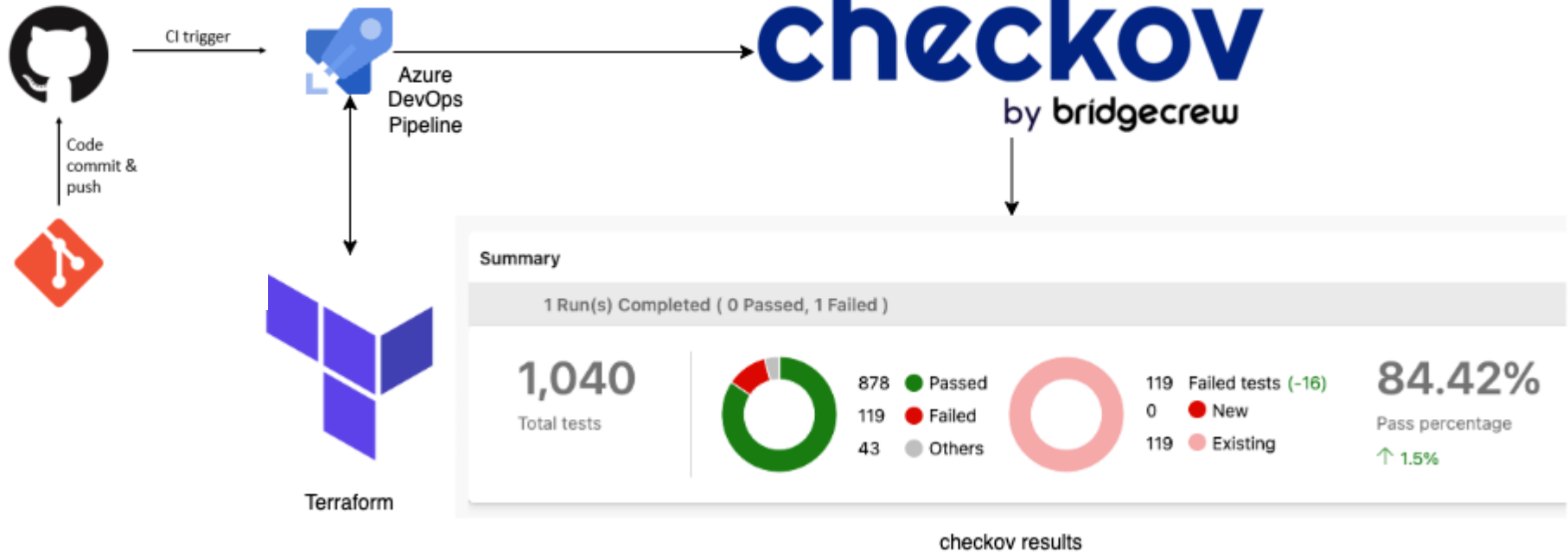
Output: Sarif

GitHub Code Scanning

Pretty HTML report - Azure DevOps

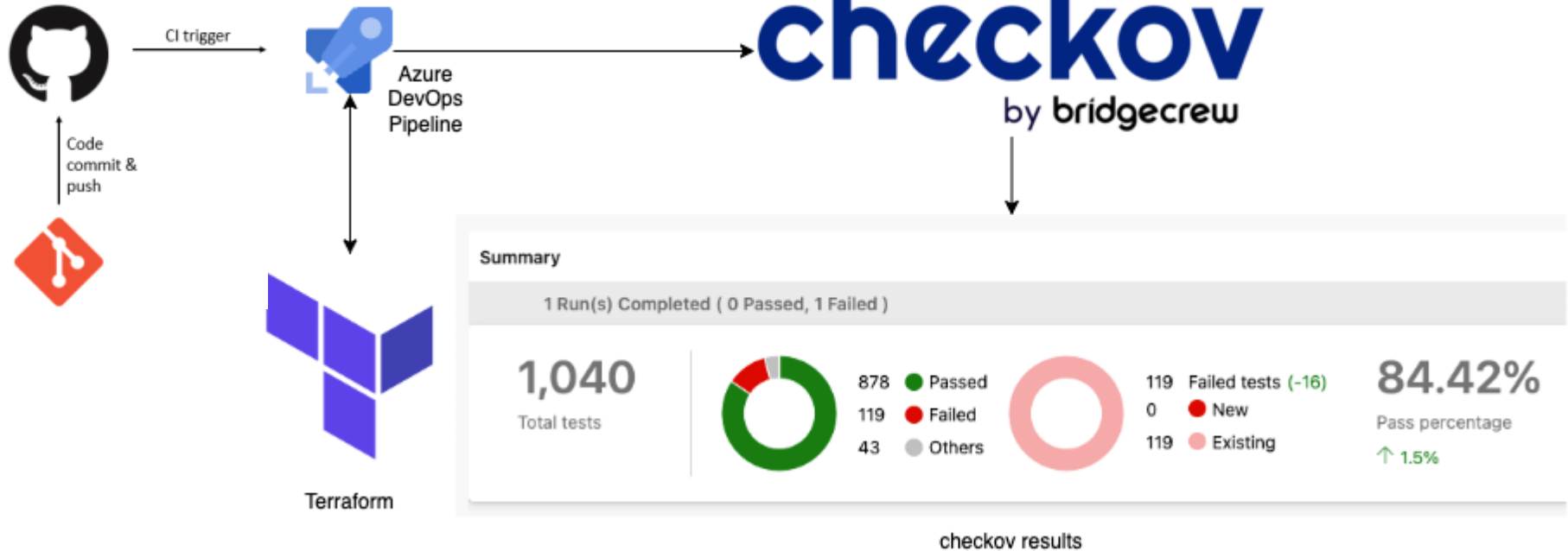


Pretty HTML report - Azure DevOps



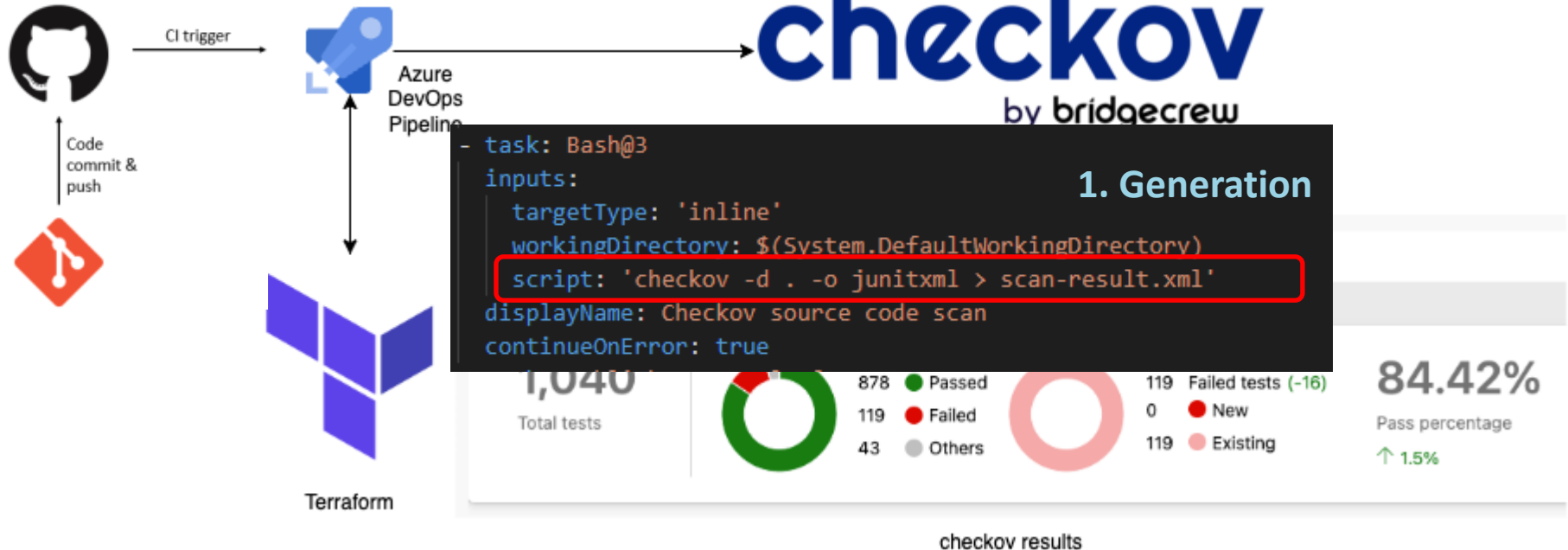
Pretty HTML report - Azure DevOps

Output: JUNITXML



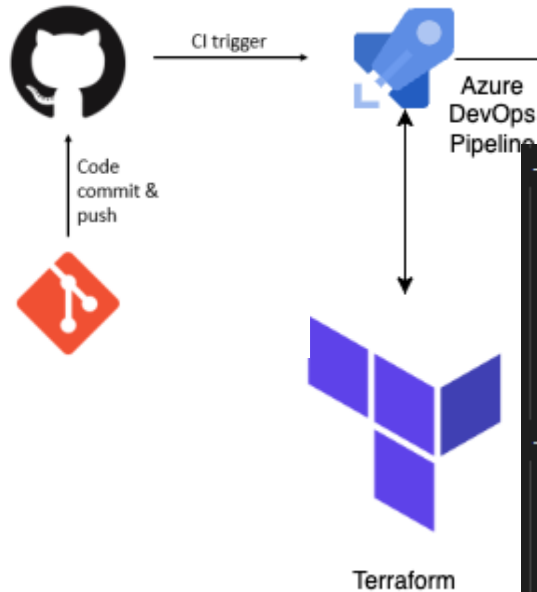
Pretty HTML report - Azure DevOps

Output: JUNITXML



Pretty HTML report - Azure DevOps

Output: JUNITXML



checkov
by bridgecrew

```
- task: Bash@3
  inputs:
    targetType: 'inline'
    workingDirectory: $(System.DefaultWorkingDirectory)
    script: 'checkov -d . -o junitxml > scan-result.xml'
  displayName: Checkov source code scan
  continueOnError: true
- task: PublishTestResults@2
  inputs:
    testResultsFormat: 'JUnit'
    searchFolder: '$(System.DefaultWorkingDirectory)'
    testResultsFiles: '**/*scan-result.xml'
    mergeTestResults: false
    testRunTitle: Terraform source code scan
    failTaskOnFailedTests: false
    publishRunAttachments: true
  displayName: Publish Test Result
```

1. Generation

84.42%

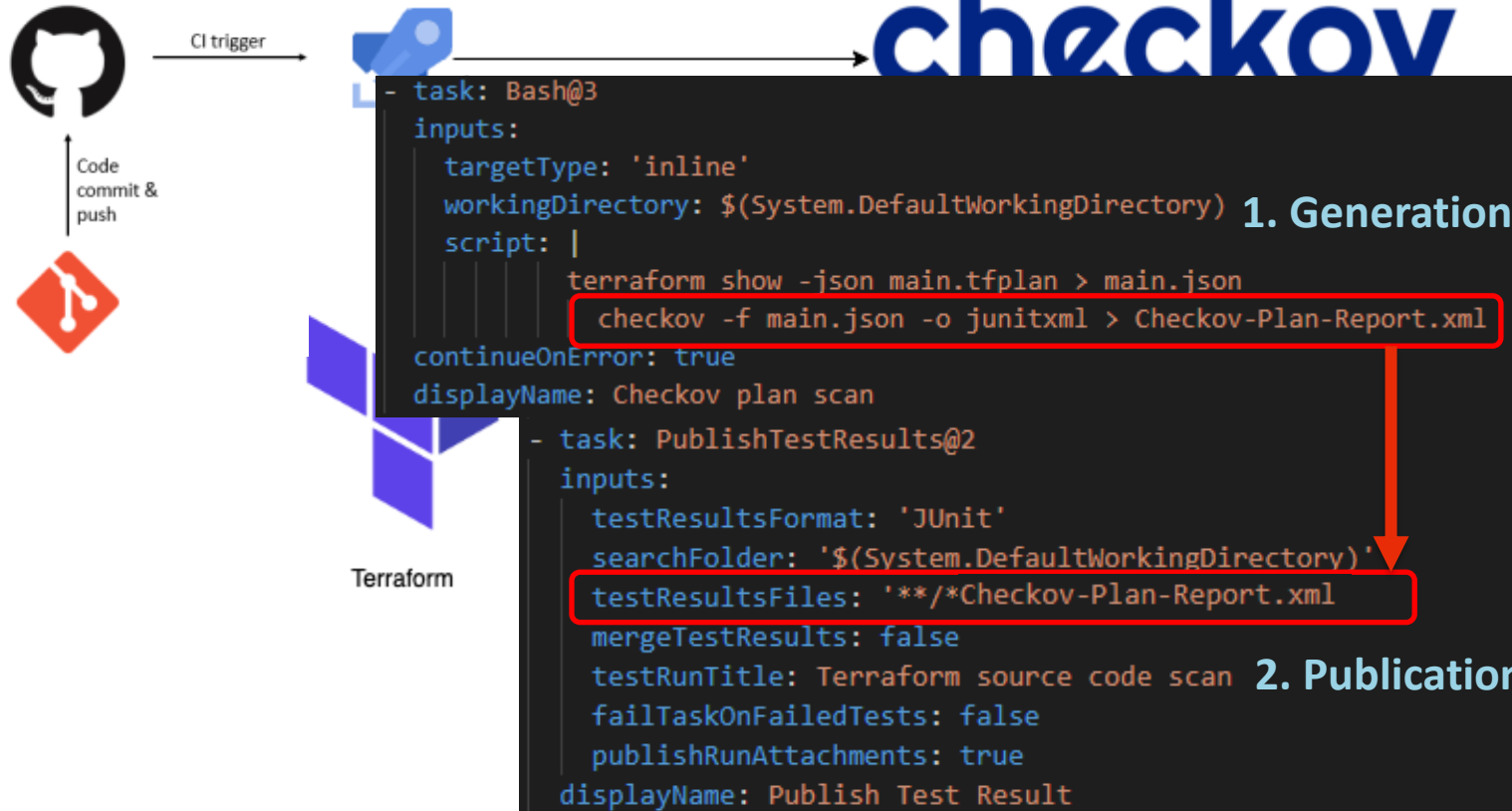
Pass percentage

↑ 1.5%

2. Publication

Pretty HTML report - Azure Devops

Output: JUNITXML



84.42%

Pass percentage

↑ 1.5%

Pretty HTML report - Azure Devops

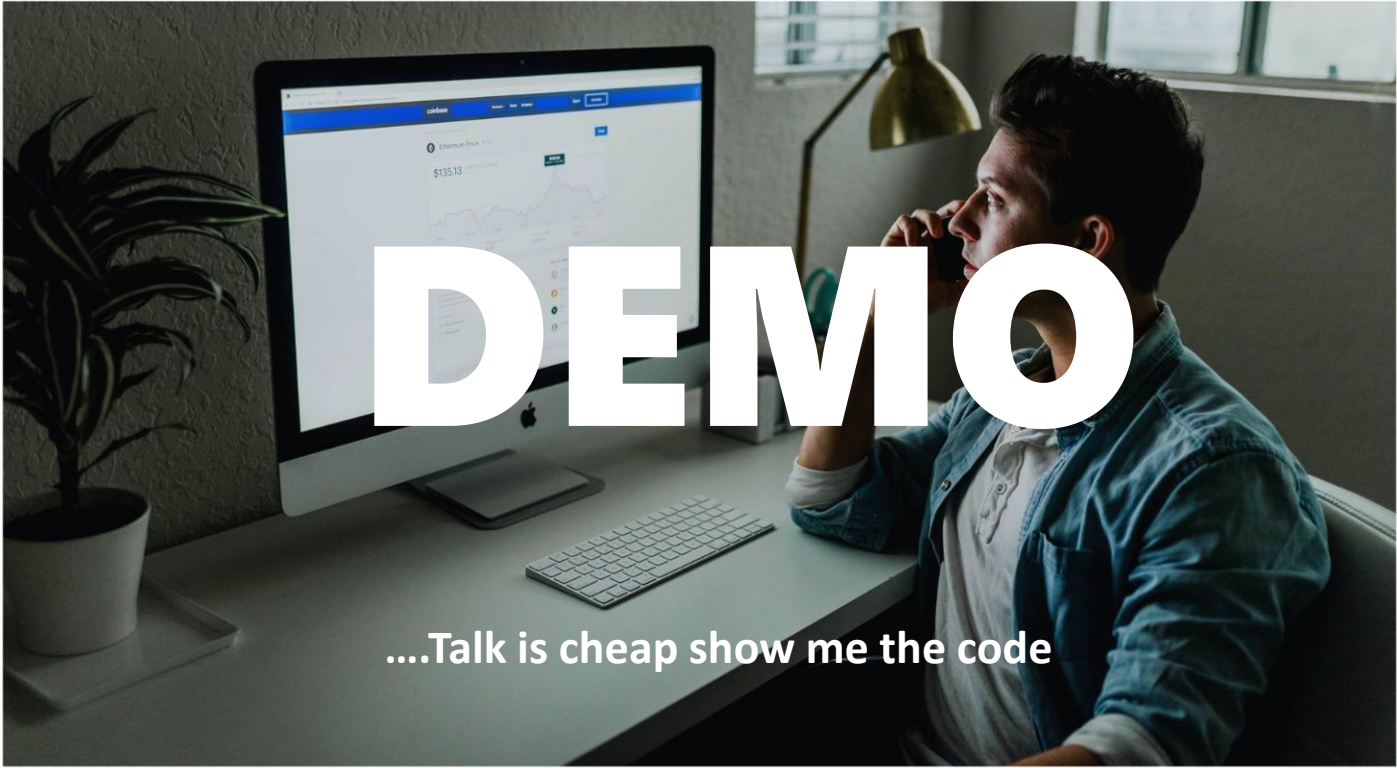
Output: JUNITXML

```
- task: Bash@3
  inputs:
    targetType: 'inline'
    workingDirectory: $(System.DefaultWorkingDirectory)
    script: |
      terraform show -json main.tfplan > main.json
      checkov -f main.json -o junitxml > Checkov-Plan-Report.xml
  continueOnError: true
  displayName: Checkov plan scan
```

1. Generation



Deploy using Terraform



DEMO

....Talk is cheap show me the code

OIDC in GitHub actions



THANK YOU



`Tech Beats unplugged`

**Tech Beats
Unplugged**



Cloud Dude

Kosseila Hd

Solutions architect @Eclipsys



Brokedba.com



Twitter.com/CloudDude_



Linkedin.com/in/kousshd



GitHub.com/brokedba



`Tech Beats unplugged`



Cloud Dude

Kosseila Hd

Solutions architect @Eclipsys



[Brokedba.com](https://brokedba.com)



[Linkedin.com/in/kousshd](https://linkedin.com/in/kousshd)



[GitHub.com/brokedba](https://github.com/brokedba)



[Twitter.com/CloudDude_](https://twitter.com/CloudDude_)